

Projektdokumentation

Betrieblicher IT-Prozess

Einführung eines Zero-Trust-Sicherheitskonzepts mit automatisierter Rechtevergabe und GitHub-basierter Workflow-Integration



Im Rahmen der Fortbildungsprüfung 2026 zum
Certified IT Business Manager

Prüfungsteilnehmer	Daniel Massa
Anschrift	Hackstraße 41, 70190 Stuttgart
Telefon	+49 178 2989360
E-Mail	Massa.Daniel@proton.me
Prüflingsnummer	615951
Praktikumsbetrieb	Verein zur Förderung der Berufsbildung e. V., Kurfürstenstraße 6, 71636 Ludwigsburg
Projektfeld	IT-Projektmanagement / IT-Sicherheit / digitale Verwaltung / Zugriffskontrolle
Projektcoach	Carsten Vordermeier
Kontakt Projektcoach	07136 396663 / vordermeier@c-tim.de
Zuständige IHK	IHK Region Stuttgart
Abgabedatum	01.11.2026

Sperrvermerk

Die vorliegende Projektarbeit enthält projektbezogene Informationen aus dem Projekt-/Praktikumsbetrieb Verein zur Förderung der Berufsbildung e. V. Eine Weitergabe außerhalb des Prüfungs- und Freigabeprozesses ist nur mit Zustimmung des Verfassers und des beteiligten Projektbetriebs zulässig.

Management Summary und Projektüberblick

Das im IHK-Projektvorschlag beschriebene Vorhaben dient der Entwicklung eines Zero-Trust-Sicherheitsmodells inklusive automatisierter Zugriffs- und Rechtevergabe. Daniel Massa übernimmt die Rolle des Projektleiters und verantwortet die Analyse der bestehenden IT-Sicherheitsarchitektur, die Konzeption des Zero-Trust-Ansatzes, den Aufbau einer automatisierten RBAC-Rechtevergabe über GitHub-Workflows, Audit-Logs und Compliance-Nachweise sowie Test, Schulung, Abnahme und Übergabe. Im technischen Pilot stehen ein strukturierter Self-Service-Antrag, eine nachvollziehbare Genehmigung, die automatisierte Zuordnung zu GitHub-Teams und eine manipulationserschwerende Audit-Protokollierung im Mittelpunkt. Im Mittelpunkt stehen ein strukturierter Self-Service-Antrag, eine nachvollziehbare Genehmigung, die automatisierte Zuordnung zu GitHub-Teams und eine manipulationserschwerende Audit-Protokollierung. GitHub wird dabei als Workflow- und Integrationsplattform eingesetzt, nicht als vollständiger Ersatz eines unternehmensweiten Identity-and-Access-Management-Systems.

Der IHK-Projektvorschlag sieht fünf Projektphasen mit insgesamt 13 Wochen vor. Die 70 aktiven Stunden bezeichnen ausschließlich den dokumentierten Prüfungsaufwand des Prüfungsteilnehmers und nicht den Gesamtaufwand des betrieblichen Projekts. Der Pilot verwendet isolierte Testdaten und begrenzt sich auf ausgewählte Rollen und Repositories. Produktive Migrationen, unternehmensweite Rezertifizierung, privilegiertes Zugriffsmanagement und die Ablösung eines zentralen Identity Providers sind ausdrücklich ausgeschlossen.

Die technische Pilotlösung besteht aus einem React-basierten Frontend, einem FastAPI-Backend, PostgreSQL für Rollen- und Auditdaten sowie GitHub Actions beziehungsweise GitHub API für die Workflow-Automatisierung. Zwölf in den Projektunterlagen definierte Testfälle bilden die funktionale Nachweiskette; der automatisierte Testreport ist der Abgabefassung als Repository-Nachweis zuzuordnen. Der Projektvorschlag nennt einen Budgetrahmen von ca. 50.000 EUR für Lizenzen, Schulung und externe Beratung.

Ergebnis: Die Dokumentation folgt der IHK-orientierten Projektlogik Projektauftrag - Planung - Spezifikation - Durchführung - Test - Abschluss. Die persönliche Projektleiterleistung, Entscheidungswege, Controlling-Instrumente und technischen Nachweise sind durchgängig sichtbar.

Inhaltsverzeichnis

1 Projektinformationen und Initiierung	1
1.1 Projektumfeld und Ausgangslage	1
1.2 Problemstellung	1
1.3 Projektziel	2
1.4 Projektbegründung	2
1.5 Projektabgrenzung	2
1.6 Rahmenbedingungen	3
1.7 Projektauftrag	3
1.8 Persönliche Projektrolle und Eigenleistung	4
2 Projektmanagement	5
2.1 Projektdefinition und Kick-off	5
2.2 Vorgehensmodell	5
2.3 Projektstrukturplan	5
2.4 Zeit- und Aufwandplanung	6
2.5 Ressourcenplanung	7
2.6 Kostenplanung	7
2.7 Stakeholder- und Kommunikationsplanung	8
2.8 Risiko- und Qualitätsplanung	8
2.9 Meilensteine und Projektcontrolling	10
2.20 RACI und Entscheidungswege	11
2.21 Change- und Claim-Management	12
2.22 Projektmarketing und Akzeptanz	13
3 Spezifikationsphase und Lösungsentscheidung	14
3.1 Ist-Prozess	14
3.2 Anforderungen	14
3.3 Zero-Trust-Leitprinzipien	14
3.4 Variantenvergleich und Make-or-Buy	15
3.5 Datenschutz- und Sicherheitsanforderungen	16
3.6 Budget- und Wirtschaftlichkeitsrahmen	16
3.7 Bedrohungsmodell	17
3.8 Datenschutzbewertung der Datenfelder	18
3.9 Abnahmekriterien und Definition of Done	19
3.10 Nachkalkulation und Wirtschaftlichkeitsnachweis	20

4 Technische Konzeption	21
4.1 Zielarchitektur	21
4.2 GitHub-Rollenworkflow	21
4.3 Rollen- und Berechtigungsmodell	22
4.4 Datenmodell	22
4.5 Audit- und Integritätskonzept	24
4.6 Schnittstellen	24
4.7 Technische Sicherheitsmaßnahmen	24
4.8 API-Vertrag und Statusmodell	25
4.9 Deployment- und Konfigurationskonzept	26
4.10 Fehler-, Retry- und Wiederanlaufkonzept	27
4.11 Logging, Monitoring und Datenschutz	28
5 Durchführungsphase	29
5.1 Entwicklungsumgebung und Repository	29
5.2 Backend und Policy-Prüfung	29
5.3 Self-Service-Oberfläche	29
5.4 GitHub-Automatisierung	29
5.5 Audit-Protokollierung	29
5.6 Qualitätssicherung in der Umsetzung	29
5.7 Abweichungsmanagement	30
5.8 Implementierungsentscheidungen	30
5.9 Dokumentations- und Repository-Struktur	32
6 Test- und Pilotphase	33
6.1 Teststrategie	33
6.2 Testfälle	33
6.3 Fehler- und Abweichungsanalyse	34
6.4 Soll-Ist-Vergleich	34
6.5 Abnahmevoraussetzungen	35
6.6 Evidenz- und Reproduzierbarkeitskonzept	36
6.7 Abnahme- und Restpunktelogik	37
6.8 Projektstatusbericht zum Dokumentationsstichtag	37
7 Rollout, Schulung und Betriebsübergabe	38
7.1 Pilotbetrieb	38
7.2 Schulungs- und Kommunikationskonzept	38
7.3 Betriebsübergabe	38

7.4 Rollout- und Skalierungsroadmap	38
7.5 Betriebsmodell und Verantwortungsübergang	39
8 Projektabschlussphase und Wirtschaftlichkeit	40
8.1 Projektergebnis	40
8.2 Kosten- und Nutzenbewertung	40
8.3 Lessons Learned	40
8.4 Restrisiken	40
8.5 Persönliches Fazit	41
8.6 Gesamtbewertung gegen das magische Dreieck	41
9 Quellen und methodische Grundlagen	42
Anhang	44
A1 Bestätigte Projektstammdaten und Zeitplan	44
A1.1 Detaillierter Zeitplan	44
A2 Projektstrukturplan	44
A3 Risikoanalyse	46
A4 Architektur und Workflow	47
A5 Datenmodell und Audit	48
A6 Anforderungs- und Testnachweis	49
A7 Testprotokoll	50
A8 Abnahmevorlage	51
A9 Budget- und Nachkalkulationsrahmen	52
A10 Rollout-Roadmap	53
A11 Kick-off- und Gesprächsprotokoll	54
A12 Projektstatusbericht	55

Abbildungs- und Tabellenverzeichnis

Die folgenden Artefakte sind Bestandteil der konsolidierten Fassung.
Die Seitenzuordnung ergibt sich aus den jeweiligen Bild- und Tabellenunterschriften.

Abbildung 1: SWOT-Analyse

Abbildung 2: Projektstrukturplan

Abbildung 3: Zeitlicher Projektverlauf

Abbildung 4: Stakeholder-Matrix

Abbildung 5: Risikomatrix

Abbildung 6: Nutzwertvergleich

Abbildung 7: Zielarchitektur

Abbildung 8: GitHub-Rollenworkflow

Abbildung 9: RBAC-Datenmodell

Abbildung 10: Audit-Hash-Kette

Abbildung 11: Testübersicht

Abbildung 12: Budgetrahmen laut Projektvorschlag

Abbildung 13: Einführungsroadmap

Abbildung 14: Traceability-Matrix

Tabellen: Projektziele, Projektabgrenzung, Zeitplanung, Ressourcen, Kosten, Kommunikation, Risiken, Anforderungen, Varianten, Rollen, Schnittstellen, Testfälle, Soll-Ist-Vergleich und Restmaßnahmen.

Abkürzungsverzeichnis

Tabelle 1: Abkürzungen

Abkürzung	Bedeutung
API	Application Programming Interface
CI/CD	Continuous Integration / Continuous Delivery
DSGVO	Datenschutz-Grundverordnung
IAM	Identity and Access Management
IGA	Identity Governance and Administration
IDP	Identity Provider
MFA	Multi-Faktor-Authentifizierung
NIST	National Institute of Standards and Technology
OPA	Open Policy Agent
RBAC	Role-Based Access Control
REST	Representational State Transfer
SSO	Single Sign-On
TOM	Technische und organisatorische Maßnahmen
UAT	User Acceptance Test

1 Projektinformationen und Initiierung

1.1 Projektumfeld und Ausgangslage

Die Projektarbeit behandelt einen sicherheitsorientierten Berechtigungsprozess beim Verein zur Förderung der Berufsbildung e. V. im Projektumfeld IT-Projektmanagement, IT-Sicherheit, digitale Verwaltung und Zugriffskontrolle. Der Projektvorschlag adressiert die bestehende IT-Sicherheitsarchitektur und die GitHub-basierte Automatisierung von Rollen- und Rechtevergaben.

Berechtigungsänderungen wurden bislang überwiegend über unstrukturierte Kommunikationswege angestoßen. Dadurch entstehen Medienbrüche, uneinheitliche Freigaben und ein erhöhter Aufwand bei der späteren Nachvollziehbarkeit.

Die im Ausgangsdokument genannten Mengen- und Fehlerwerte werden in dieser Fassung nicht als ungeprüfte Unternehmenskennzahlen übernommen. Für die Kostenplanung wird der im IHK-Projektvorschlag bestätigte Budgetrahmen verwendet. Produktivwerte und tatsächliche Kosten dürfen erst nach einer dokumentierten Stichprobe, Zeiterfassung oder Belegauswertung als Ist-Werte bezeichnet werden.

1.2 Problemstellung

Ein Berechtigungsprozess muss fachlich korrekt, technisch reproduzierbar und organisatorisch verantwortbar sein. Bei manuellen E-Mail-Verfahren fehlen häufig Pflichtfelder, ein eindeutiger Genehmigungsstatus, eine standardisierte Zuordnung zu Rollen und ein zentraler Audit-Nachweis. Das Risiko besteht sowohl in zu weitreichenden als auch in nicht rechtzeitig entzogenen Berechtigungen.

Zero Trust bedeutet in diesem Projekt nicht die vollständige Neugestaltung der Unternehmensarchitektur. Das Prinzip wird auf den ausgewählten Anwendungsfall übertragen: Jeder Antrag wird identitätsbezogen geprüft, jede Entscheidung wird explizit genehmigt, jede Berechtigung wird minimal vergeben und jeder Schritt wird protokolliert.

1.3 Projektziel

Innerhalb von 70 aktiven Arbeitsstunden wird ein technisch funktionsfähiger Pilot entwickelt, der Rollenanforderungen erfasst, Pflichtfelder und Policies prüft, eine Genehmigungsentscheidung abbildet, die vorgesehene GitHub-Teamzuordnung ausführt beziehungsweise simuliert und einen strukturierten Audit-Eintrag erzeugt.

Tabelle 2: SMART-orientierte Projektziele

Ziel	Messgröße	Abnahmekriterium
Rollenmodell	mindestens 6 Pilotrollen	Rollenmatrix dokumentiert
Workflow	Antrag - Prüfung - Genehmigung - Provisioning - Benachrichtigung	End-to-End-Test nachvollziehbar
Audit	100 % der Pilotaktionen protokolliert	Audit-Eintrag mit Zeit, Akteur, Aktion und Ergebnis
Tests	12 definierte Testfälle	automatisierter Testlauf ohne kritischen Fehler
Dokumentation	Architektur, Betrieb, Nutzung, Risiken	vollständige Übergabeunterlagen

1.4 Projektbegründung

Der Pilot reduziert das Projektrisiko gegenüber einer sofortigen unternehmensweiten Einführung. Er schafft eine belastbare Entscheidungsgrundlage, demonstriert die technische Integrationsfähigkeit und macht organisatorische Anforderungen sichtbar. Gleichzeitig begrenzt er Kosten und verhindert, dass im Prüfungsprojekt ein vollständiges Enterprise-IAM versprochen wird, das innerhalb von 70 Stunden nicht seriös realisierbar wäre.

1.5 Projektabgrenzung

Tabelle 3: Projektumfang und Abgrenzung

Im Projekt enthalten	Nicht im Projekt enthalten
Rollen- und Berechtigungskatalog für den Pilot	Ablösung von Active Directory oder zentralem IDP
Self-Service-Formular und Genehmigungsworkflow	unternehmensweiter Produktivrollout
GitHub-API-/Actions-Integration	Privileged Access Management
Audit-Protokollierung und Export	vollständige Identitätsrezertifizierung
Testkonzept und Übergabedokumentation	rechtliche Bestätigung einer Revisionssicherheit

Die klare Abgrenzung ist ein zentrales Qualitätsmerkmal: Der Pilot liefert einen Machbarkeitsnachweis und eine skalierbare Referenzarchitektur, jedoch keine vollständige Identity-Governance-Plattform.

1.6 Rahmenbedingungen

Die technische Umsetzung verwendet vorhandene beziehungsweise frei verfügbare Entwicklungswerkzeuge. Personenbezogene Produktivdaten werden nicht benötigt. Für Screenshots und Tests sind synthetische oder pseudonymisierte Testidentitäten einzusetzen. Externe Schnittstellen werden im Pilot nur mit minimalen Berechtigungen und getrennten Testzugängen angesprochen.



Abbildung 1: SWOT-Analyse des abgegrenzten Pilotprojekts

1.7 Projektauftrag

Der Projektauftrag lautet: Planung, prototypische Umsetzung und Bewertung eines standardisierten Zero-Trust-Rollenworkflows mit GitHub-Integration. Der Auftrag umfasst die Projektsteuerung, Anforderungsanalyse, Variantenentscheidung, Architektur, Implementierung, Testdurchführung und Dokumentation. Die betriebliche Produktivfreigabe bleibt eine nachgelagerte Entscheidung des Auftraggebers.

1.8 Persönliche Projekttrolle und Eigenleistung

Ich übernahm die Rolle des Projektleiters und setzte zugleich die zentralen technischen Arbeitspakete des Piloten um. Zu meiner Eigenleistung gehörten die Strukturierung des Projektauftrags, die Erstellung der Ziel- und Anforderungsmatrix, die Auswahl und Bewertung der Lösungsvarianten, die Entwicklung der Zielarchitektur, die Umsetzung des Rollenworkflows, die Definition und Auswertung der Tests sowie das Projektcontrolling und die Abschlussdokumentation.

Beratende Beiträge aus Datenschutz, Administration oder fachlicher Freigabe werden getrennt ausgewiesen. Die Verantwortung für organisatorische Freigaben verbleibt beim jeweiligen Auftraggeber beziehungsweise Rollenowner; technische Automatisierung ersetzt keine Managemententscheidung.

2 Projektmanagement

2.1 Projektdefinition und Kick-off

Zum Projektstart wurden Projektziel, Nicht-Ziele, Rollen, Kommunikationswege und die geplanten Liefergegenstände in einem Kick-off strukturiert. Die Detailplanung war noch nicht vollständig abgeschlossen; die abgestimmten Rahmenbedingungen reichten jedoch aus, um ein gemeinsames Projektverständnis herzustellen und Verantwortlichkeiten zu klären.

Tabelle 4: Kick-off-Ergebnisse

Agenda	Ergebnis
Ausgangslage und Nutzen	gemeinsames Verständnis des Sicherheits- und Automatisierungsbedarfs
Projektziel und Abgrenzung	70-Stunden-Pilot statt vollständigem Enterprise-IAM
Rollen und Verantwortungen	Projektleiter, Auftraggeber, IT-Administration, Datenschutz und Pilotnutzer abgegrenzt
Vorgehen und Meilensteine	hybrides Phasenmodell und sechs Freigabepunkte vereinbart
Kommunikation und Ablage	Statusbericht, Review-Protokoll und Repository als Projekttakte festgelegt

Ein kompaktes Gesprächsprotokoll und ein Projektstatusbericht sind im Anhang als prüfbare Projektartefakte aufgenommen. Dadurch wird nicht nur beschrieben, dass Kommunikation stattgefunden hat, sondern auch, welche Entscheidungen und Verantwortlichkeiten daraus entstanden.

2.2 Vorgehensmodell

Für den Pilot wird ein hybrides Vorgehensmodell eingesetzt. Projektauftrag, Zieldefinition, Architektur und Abnahmebedingungen werden planorientiert festgelegt. Die Umsetzung erfolgt iterativ in kurzen Entwicklungszyklen. Dadurch bleiben Scope, Termine und Prüfbarkeit stabil, während technische Erkenntnisse unmittelbar berücksichtigt werden können.

Die iterative Umsetzung umfasst jeweils Planung, Implementierung, automatisierten Test und Review. Änderungen am Projektumfang werden nicht informell aufgenommen, sondern gegen Zeitbudget, Risiko und Nutzen bewertet.

2.3 Projektstrukturplan

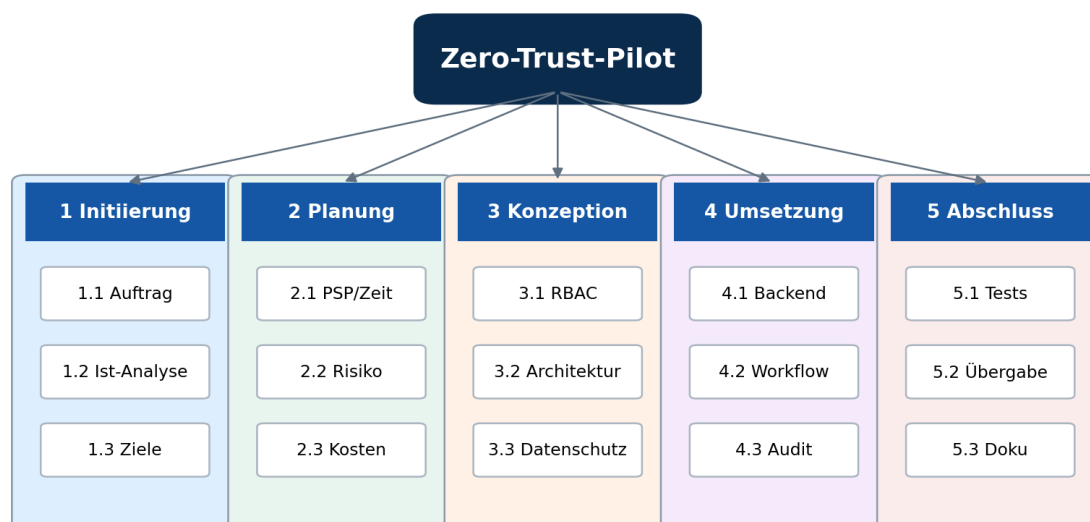


Abbildung 2: Projektstrukturplan des Zero-Trust-Piloten

2.4 Zeit- und Aufwandplanung

Tabelle 5: Konsolidierte 70-Stunden-Planung

Phase laut Antrag	Wesentliche Arbeitspakete	Stunden
1 Projektinitialisierung und Analyse	Projektauftrag, Ist-Analyse, Anforderungen, Risikoprofil	15
2 Konzept und Architekturdesign	Zero-Trust-Framework, Architektur-Blueprint, Stakeholderfreigabe	15
3 Implementierung und GitHub-Integration	RBAC, Workflows, Schnittstellen, Audit- und Sicherheitsprüfungen	25
4 Test und Schulung	Funktionstests, Audit-Prüfung, Schulungskonzept und Feedback	8
5 Projektabschluss und Übergabe	Dokumentation, Abnahmevorbereitung, Lessons Learned und Übergabe	7
Gesamt		70

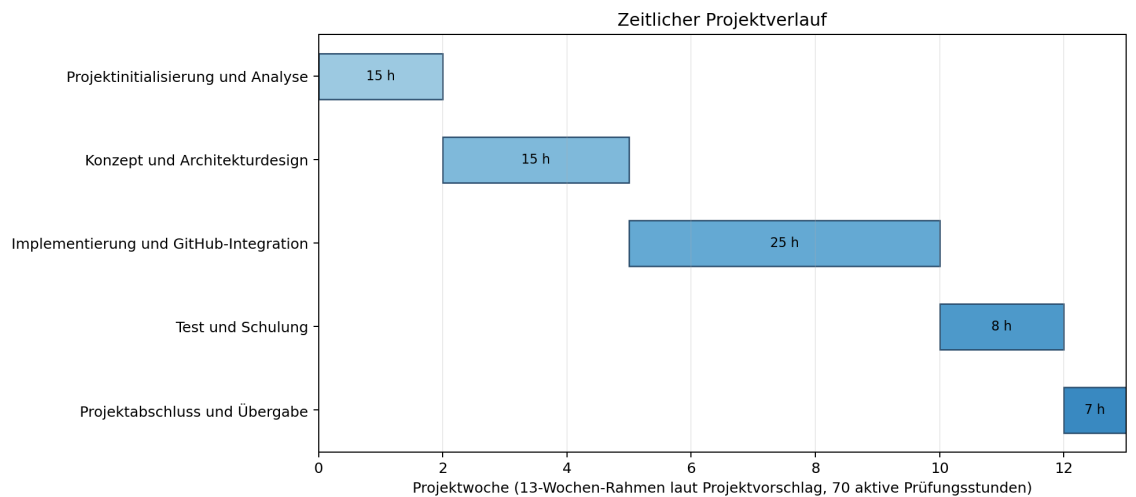


Abbildung 3: Zeitlicher Projektverlauf im 13-Wochen-Rahmen laut Projektvorschlag

2.5 Ressourcenplanung

Tabelle 6: Ressourcen und Verantwortlichkeiten

Rolle / Ressource	Planwert	Verantwortung
Projektleiter Daniel Massa	70 aktive Prüfungsstunden	Projektauftrag, Analyse, Konzeption, Steuerung, Nachweise und Dokumentation
2 IT-Spezialisten	gemäß Projektvorschlag	Infrastruktur, technische Machbarkeit und Integration
1 Entwickler für Automatisierung	gemäß Projektvorschlag	GitHub-Workflows, Provisionierung und Schnittstellen
1 externer Compliance-Berater	gemäß Projektvorschlag	Compliance- und Sicherheitsreview
Projektcoach Carsten Vordermeier	projektbegleitend	fachliche Begleitung im Projekt-/Praktikumsbetrieb

2.6 Kostenplanung

Tabelle 7: Einheitliche Kostenplanung

Kosten-/Budgetbezug	Grundlage	Wert
Gesamtbudget	IHK-Projektvorschlag vom 30.09.2026	ca. 50.000 EUR
Budgetkategorien	Lizenzen, Schulung, externe Beratung	gemäß Projektvorschlag
Prüfungsaufwand Daniel Massa	aktive persönliche Projektarbeit	70 Stunden
Ist-Kosten	Angebote, Rechnungen und interne Verrechnungssätze	vor Abgabe nachzuweisen

Die Kostenrechnung verwendet einen einheitlichen kalkulatorischen Stundensatz. Bereits vorhandene Plattformen und Open-Source-Komponenten werden nicht als neue Lizenzkosten angesetzt. Etwaige spätere Betriebs-, Support- oder Enterprise-Lizenzkosten sind nicht Bestandteil des Piloten und müssen

vor einem Rollout separat bewertet werden.

2.7 Stakeholder- und Kommunikationsplanung

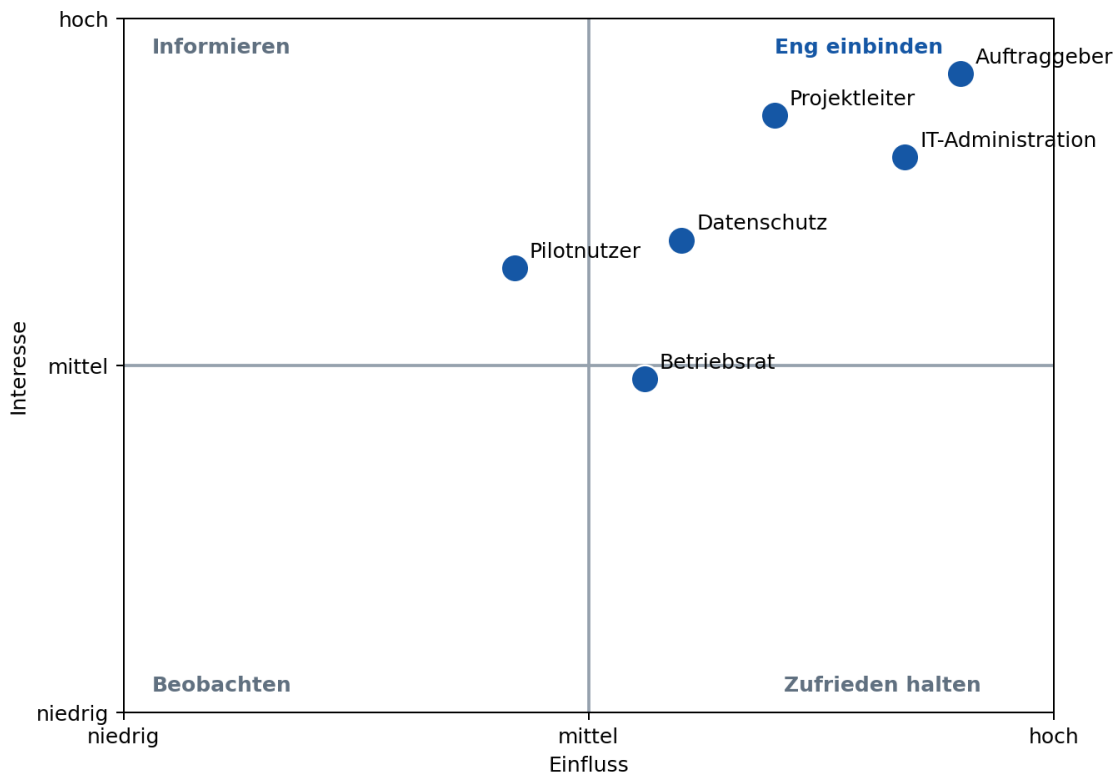


Abbildung 4: Stakeholder-Matrix

Tabelle 8: Kommunikationsplan

Stakeholder	Information	Taktung	Medium
Auftraggeber	Status, Entscheidungen, Risiken	Meilensteinbezogen	Review / Protokoll
IT-Administration	Architektur und Schnittstellen	wöchentlich	Technik-Review
Datenschutz	Datenfelder, Aufbewahrung, TOM	Konzept- und Testphase	Checkliste / Review
Pilotnutzer	Bedienung und Rückmeldung	Testphase	Kurzschulung / Feedback
Prüfungsdokumentation	Nachweise und Abweichungen	laufend	Repository / Projektakte

2.8 Risiko- und Qualitätsplanung

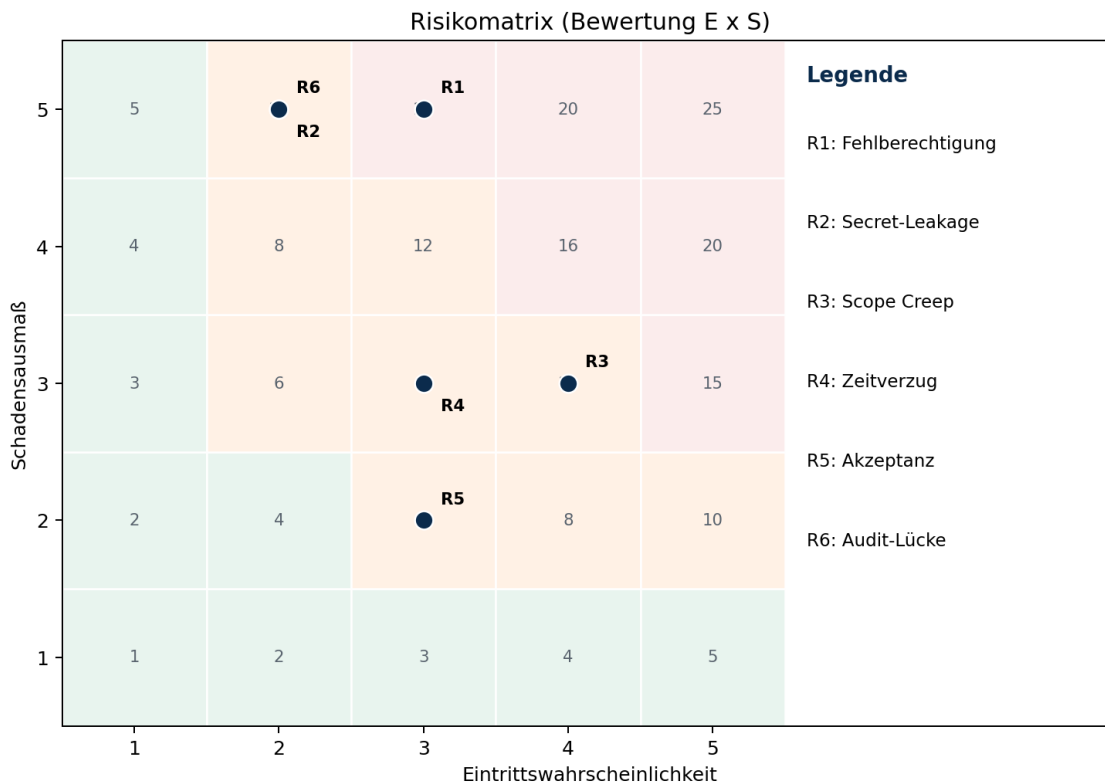


Abbildung 5: Risikomatrix des Piloten

Tabelle 9: Risikobehandlung

Risiko	Bewertung	Prävention	Reaktion
Fehlberechtigung	hoch	Rollenmatrix, Vier-Augen-Prinzip	Entzug, Audit, Ursachenanalyse
Secret-Leakage	hoch	Secrets Store, Scanner, Testtoken	Token sperren und ersetzen
Scope Creep	mittel	Abgrenzung, Change-Entscheidung	Anforderung verschieben
Zeitverzug	mittel	Meilensteine, Puffer, Priorisierung	Kann-Anforderung entfernen
Audit-Lücke	hoch	Pflichtlogging, Tests	Blockierung des Provisionings

Qualitätskriterien sind Nachvollziehbarkeit, reproduzierbare Tests, eindeutige Anforderungen, minimale Berechtigungen, sichere Geheimnisverwaltung und konsistente Dokumentation. Eine Funktion gilt erst als abgeschlossen, wenn ihr Anforderungsbezug und ihr Testnachweis dokumentiert sind.

2.9 Meilensteine und Projektcontrolling

Das Projektcontrolling verbindet Termin-, Kosten-, Qualitäts- und Umfangssteuerung. Zu jedem Meilenstein werden der erreichte Liefergegenstand, offene Risiken, verbrauchte Stunden und notwendige Entscheidungen dokumentiert. Reine Aktivitätsmeldungen reichen nicht aus; entscheidend ist der nachweisbare Fertigstellungsgrad.

Tabelle 10: Meilenstein- und Freigabeplan

Meilenstein	Liefergegenstand	Freigabekriterium
M1 Initiierung	Projektauftrag und Abgrenzung	Ziele, Scope und 70-h-Rahmen bestätigt
M2 Analyse	Anforderungen und Risikoregister	Muss-Anforderungen testbar formuliert
M3 Entwurf	Architektur und Datenmodell	Schnittstellen und Pilotgrenze geprüft
M4 Prototyp	lauffähiger End-to-End-Pfad	Dry-Run oder Test-API erfolgreich
M5 Test	Testprotokoll und Fehlerliste	keine offenen kritischen Befunde
M6 Abschluss	Dokumentation und Übergabepaket	Restmaßnahmen und Abnahmestatus eindeutig

Bei einer erkennbaren Terminabweichung wird zuerst der Umfang der Kann-Anforderungen reduziert. Eine Erhöhung der offiziellen Prüfungszeit ist keine zulässige Standardreaktion. Technische Laufzeiten automatisierter Jobs werden nur dann als Arbeitszeit erfasst, wenn eine aktive Bearbeitung oder Auswertung stattfindet.

2.20 RACI und Entscheidungswege

Die RACI-Zuordnung verhindert Mehrfachverantwortung und ungeklärte Freigaben. Für jede kritische Aktivität wird genau eine accountable Rolle festgelegt. Das technische System kann Aktivitäten ausführen, aber keine organisatorische Verantwortung übernehmen.

Tabelle 11: RACI-Matrix

Aktivität	Prüfling/PL	Auftraggeber	IT-Admin	Datenschut z	Pilotnutzer
Projektauftrag	R	A	C	C	I
Architektur	R	C	A/C	C	I
Rollenfreigabe	C	A	R	C	I
Implementierung	R/A	I	C	I	I
Datenschutzreview	C	I	C	R/A	I
Pilotabnahme	R	A	C	C	C

Strategische Änderungen an Scope, Sicherheitsniveau oder betrieblicher Nutzung müssen durch den Auftraggeber entschieden werden. Der Projektleiter steuert die Umsetzung und dokumentiert Auswirkungen auf Zeit, Kosten, Risiko und Qualität.

2.21 Change- und Claim-Management

Änderungswünsche werden in einem Change-Log erfasst. Jeder Eintrag enthält Anlass, Nutzen, Aufwand, Risiko, Entscheidung und Zielversion. Im Prüfungsprojekt werden Änderungen nur umgesetzt, wenn sie ein Muss-Kriterium sichern oder ohne Gefährdung des Stundenrahmens realisierbar sind.

Tabelle 12: Beispielhafte Änderungsentscheidungen

Change	Bewertung	Entscheidung
Produktives Azure-AD-SSO	hoher Integrations- und Freigabeaufwand	in Folgerollout verschoben
KI-Anomalieerkennung	kein Beitrag zu Muss-Kriterien	aus Scope entfernt
Hash-Verkettung im Audit	erhöht Manipulationserkennung	im Pilot umgesetzt
E-Mail-Eskalation	zusätzliche Abhängigkeit	als Mock/Benachrichtigung abgebildet

Claim-Management ist im internen Pilot nur eingeschränkt relevant. Dennoch werden Zusagen, Annahmen und Abhängigkeiten dokumentiert, damit aus einer informellen Erwartung keine unbemerkte Leistungsverpflichtung entsteht.

2.22 Projektmarketing und Akzeptanz

Projektmarketing richtet sich nicht auf werbliche Überhöhung, sondern auf Verständlichkeit und Akzeptanz. Die Kernbotschaft lautet: weniger unstrukturierte Rückfragen, nachvollziehbare Entscheidungen und klar definierte Rollen. Sicherheitskontrollen werden als Unterstützung eines verlässlichen Arbeitsprozesses erklärt.

- Stakeholder erhalten zielgruppengerechte Informationen statt technischer Detailflut.
- Pilotnutzer sehen Rollenbeschreibung, Bearbeitungsstatus und erwartete Genehmigungszeit.
- Führungskräfte erhalten Risiko-, Nutzen- und Entscheidungsinformationen.
- IT und Datenschutz erhalten technische Nachweise, Restmaßnahmen und Betriebsgrenzen.

Akzeptanz wird nicht nur über Zufriedenheitswerte bewertet. Ebenso relevant sind vollständige Anträge, geringe Rückfragen, korrekt ausgeführte Rollenentscheidungen und die Fähigkeit der Beteiligten, den Prozess ohne Projektteam zu bedienen.

3 Spezifikationsphase und Lösungsentscheidung

3.1 Ist-Prozess

Der betrachtete Ausgangsprozess ist durch unstrukturierte Anträge, manuelle Rückfragen und heterogene Nachweise geprägt. Typische Schritte sind Antrag, fachliche Zustimmung, technische Umsetzung und informelle Rückmeldung. Die Bearbeitungszeit hängt stark von Vollständigkeit und Verfügbarkeit der Beteiligten ab.

Für die Projektplanung wird der Ist-Prozess qualitativ bewertet. Mengen- und Zeitwerte werden nur als Referenzszenario genutzt, solange keine belastbare Stichprobe mit Zeitraum, Fallzahl und Erhebungsmethode vorliegt. Diese Trennung verhindert, dass Planannahmen als gemessene Unternehmensleistung dargestellt werden.

3.2 Anforderungen

Tabelle 13: Anforderungsmatrix

ID	Anforderung	Typ	Priorität	Nachweis
A01	Rollenbasierte Berechtigungen	funktional	Muss	Rollenmatrix / TF07
A02	Strukturierter Self-Service-Antrag	funktional	Muss	Formular / TF01-TF02
A03	Explizite Genehmigungsentscheidung	funktional	Muss	Workflow / TF03-TF04
A04	GitHub-Teamzuordnung	funktional	Muss	API-/Simulationslog / TF07
A05	Audit-Protokollierung	nicht-funktional	Muss	Audit-Export / TF09-TF11
A06	Sicherer Rechteentzug	funktional	Muss	TF08
A07	Secret-Scanning	Sicherheit	Muss	TF10
A08	Betriebs- und Nutzerdokumentation	Organisation	Muss	Dokumentenpaket

3.3 Zero-Trust-Leitprinzipien

- Explizite Verifikation jeder Rollenanforderung und Genehmigung.
- Least Privilege: Rollen enthalten nur erforderliche Berechtigungen.
- Assume Breach: Aktionen werden protokolliert und auf Fehlerpfade getestet.
- Kurze Gültigkeit und definierter Entzug für zeitlich begrenzte Rollen.
- Trennung von Antragsteller, Genehmiger und technischem Provisioning.

Die Prinzipien werden auf den Pilotprozess abgebildet. Netzwerksegmentierung, Device Posture, Continuous Access Evaluation oder vollständige Mikrosegmentierung sind nicht Bestandteil des Projekts.

3.4 Variantenvergleich und Make-or-Buy

Bewertet werden der bestehende manuelle Prozess, eine Standard-IAM-/IGA-Lösung und ein begrenzter GitHub-Pilot. Eine Standardlösung kann die Kernanforderungen grundsätzlich abdecken, ist für den 70-Stunden-Nachweis jedoch mit höherem Lizenz-, Integrations- und Einführungsaufwand verbunden. Der Pilot wird deshalb als Lern- und Entscheidungsplattform gewählt, nicht weil Standardprodukte funktional ungeeignet wären.

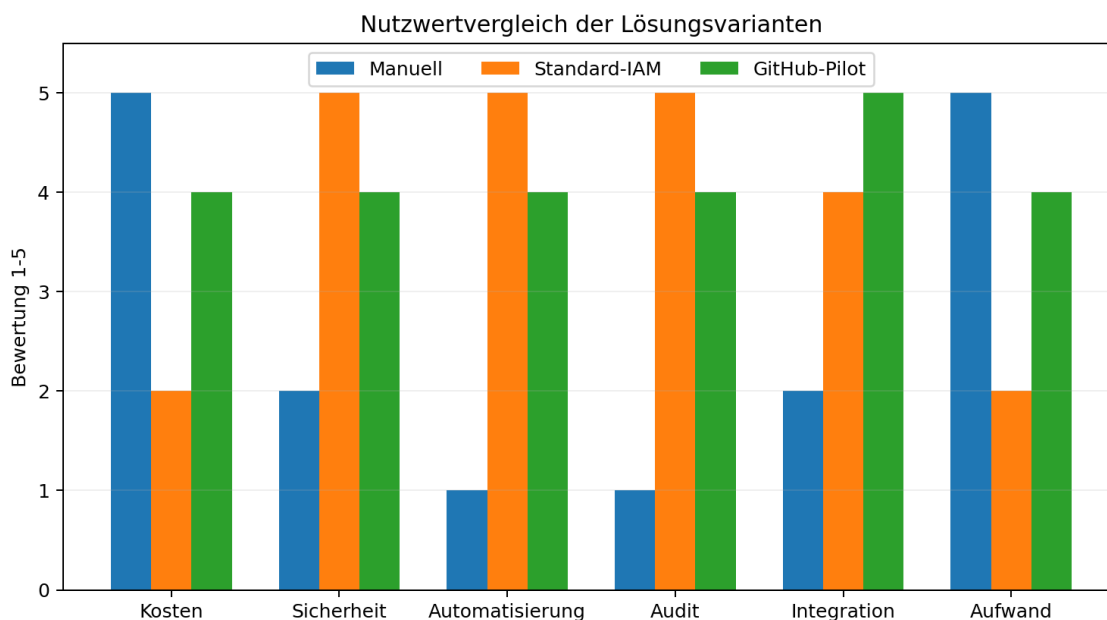


Abbildung 6: Nutzwertvergleich der Lösungsvarianten

Tabelle 14: Nutzwertanalyse

Kriterium	Gewicht	Manuell	Standard-IAM	GitHub-Pilot
Einführungskosten	15 %	5	2	4
Sicherheit	20 %	2	5	4
Automatisierung	20 %	1	5	4
Auditierbarkeit	20 %	1	5	4
Integration	15 %	2	4	5
Umsetzungsaufwand	10 %	5	2	4
Gewichtetes Ergebnis	100 %	2,4	3,8	4,2

3.5 Datenschutz- und Sicherheitsanforderungen

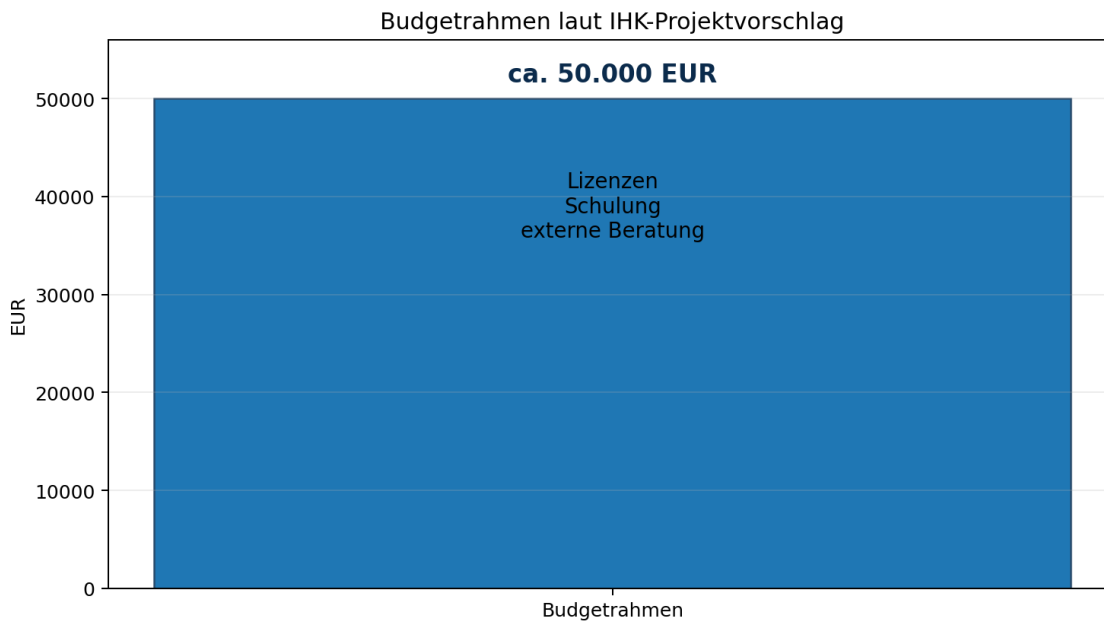
Im Pilot werden nur Identifikatoren, Rollenbezug, Genehmigungsstatus, technische Ressource und Zeitstempel verarbeitet. Freitextbegründungen sind auf das notwendige Maß zu begrenzen. Produktive Personaldaten, besondere Kategorien personenbezogener Daten und private Inhalte sind ausgeschlossen.

- Datenminimierung und Zweckbindung gemäß Art. 5 DSGVO.
- Datenschutz durch Technikgestaltung gemäß Art. 25 DSGVO.
- Angemessene technische und organisatorische Maßnahmen gemäß Art. 32 DSGVO.
- Rollenbasierte Zugriffsrechte auf Audit- und Administrationsfunktionen.
- Definiertes Lösch- und Aufbewahrungskonzept statt pauschaler unbegrenzter Speicherung.

Eine Datenschutz-Folgenabschätzung ist nur dann als durchgeführt zu bezeichnen, wenn sie tatsächlich erstellt und durch die zuständige Stelle bewertet wurde. In dieser Fassung ist sie als Prüfpunkt, nicht als ungeprüfte Erfolgsaussage, enthalten.

3.6 Budget- und Wirtschaftlichkeitsrahmen

Der eingereichte Projektvorschlag nennt einen Budgetrahmen von ca. 50.000 EUR für Lizenzen, Schulung und externe Beratung. Dieser Betrag beschreibt den geplanten betrieblichen Projektumfang. Die 70 Prüfungsstunden des Prüfungsteilnehmers sind davon getrennt auszuweisen. Eine belastbare Wirtschaftlichkeitsrechnung erfordert zusätzlich reale Angebote, interne Verrechnungssätze, Betriebs- und Wartungskosten sowie gemessene Prozessmengen.



Die 70 Prüfungsstunden des Teilnehmers sind nicht mit dem Gesamtprojektbudget gleichzusetzen.

Abbildung 7: Budgetrahmen laut IHK-Projektvorschlag

Da die vorliegenden Unterlagen keine freigegebene Detailkalkulation und keine belastbaren Ist-Prozessmengen enthalten, wird in dieser Fassung kein fiktiver Break-even behauptet. Die Nachkalkulation ist nach Projektabschluss aus Budget, Ist-Kosten, messbarer Zeitersparnis, Betriebskosten und Qualitätsnutzen zu erstellen.

3.7 Bedrohungsmodell

Das Bedrohungsmodell betrachtet Missbrauchsfälle entlang des gesamten Rollenprozesses. Angreifer können versuchen, fremde Identitäten zu verwenden, Genehmigungen zu umgehen, Workflowdateien zu verändern, Tokens auszulesen oder Auditdaten zu manipulieren. Für jeden Bedrohungspfad wird eine präventive und eine detektive Kontrolle definiert.

Tabelle 15: Bedrohungen und Kontrollen

Bedrohung	Angriffsweg	Kontrolle
Identitätsmissbrauch	gestohlene Sitzung oder Testidentität	MFA/SSO im Produktivbetrieb, kurze Sitzungen
Genehmigungsumgehung	direkter API-Aufruf	serverseitige Autorisierung und Statusmaschine
Workflow-Manipulation	ungeprüfter Commit	Branch Protection und Reviewpflicht
Token-Diebstahl	Secret im Code oder Log	Secrets Store, Scanner, Maskierung
Audit-Manipulation	direkter Datenbankzugriff	DB-Rollen, Append-only, Hash-Prüfung
Überberechtigung	zu breite Rollenmatrix	Least Privilege und Rollenowner

Das Modell dient der Priorisierung. Es ersetzt keinen Penetrationstest und keine formale Risikoanalyse für einen Produktivbetrieb.

3.8 Datenschutzbewertung der Datenfelder

Die Datenschutzbewertung beginnt auf Feldebene. Für jedes Attribut werden Zweck, Rechtsgrundlage beziehungsweise betriebliche Erforderlichkeit, Zugriff, Aufbewahrung und Löschung beschrieben. Freitextfelder erhalten besondere Aufmerksamkeit, weil dort leicht unnötige personenbezogene Inhalte erfasst werden.

Tabelle 16: Bewertung zentraler Datenfelder

Feld	Zweck	Aufbewahrung im Pilot	Schutz
user_id	Zuordnung des Antrags	bis Abschluss und definierte Nachweisfrist	pseudonymisierte Test-ID
role_id	beantragte Rolle	wie Vorgang	Rollen-Whitelist
reason	fachliche Begründung	kurz und ohne sensible Inhalte	Längen- und Inhaltshinweis
approver_id	Genehmigungsnachweis	wie Vorgang	rollenbasierter Zugriff
audit_hash	Integritätsprüfung	wie Auditdatensatz	nicht geheim, aber schreibgeschützt

Eine feste Aufbewahrungsdauer wird nicht pauschal aus der DSGVO abgeleitet. Sie muss aus betrieblichen, rechtlichen und sicherheitsbezogenen Anforderungen begründet und durch eine zuständige Stelle freigegeben werden.

3.9 Abnahmekriterien und Definition of Done

Die Definition of Done verbindet fachliche Fertigstellung, technische Qualität und Dokumentation. Eine Funktion ist nicht abgeschlossen, wenn nur eine Benutzeroberfläche oder ein positiver Demonstrationspfad existiert.

Tabelle 17: Definition of Done

Kriterium	Erforderlicher Nachweis
Anforderung eindeutig	ID, Priorität und Akzeptanzkriterium vorhanden
Implementierung geprüft	Review oder dokumentierter Selbstcheck
Positiv- und Negativtest	erwarteter Erfolg und erwartete Blockierung
Audit vollständig	Aktion, Akteur, Zeit, Ergebnis und Vorgangsbezug
Dokumentation aktualisiert	Nutzer-, Betriebs- und Architekturhinweis
Restfehler bewertet	Schweregrad, Workaround und Verantwortlicher

Die Abnahmekriterien werden vor der Umsetzung festgelegt. Damit wird verhindert, dass nachträglich nur die erfolgreich demonstrierten Funktionen als Ziel ausgegeben werden.

3.10 Nachkalkulation und Wirtschaftlichkeitsnachweis

Die Nachkalkulation trennt verbindlich zwischen Budgetrahmen, Planwerten, tatsächlich angefallenen Kosten und messbarem Nutzen. Solange Angebote, Rechnungen, interne Verrechnungssätze und Pilotmessungen nicht vollständig vorliegen, werden weder Amortisationsdauer noch ROI als Projektergebnis behauptet.

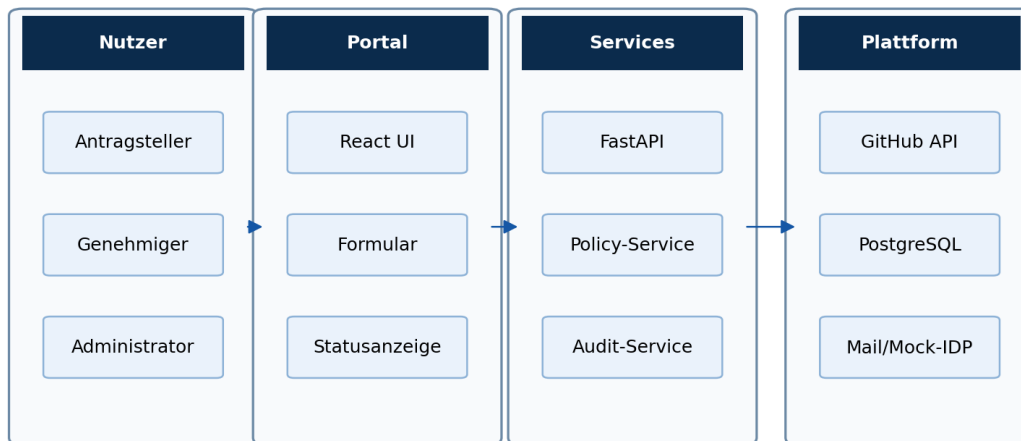
Tabelle 18: Sensitivitätsanalyse

Nachkalkulationsgröße	Quelle	Status
Budgetrahmen	IHK-Projektvorschlagn	ca. 50.000 EUR
Lizenzkosten	Angebote / Rechnungen	vor Abgabe ergänzen
Schulungskosten	Angebote / Rechnungen	vor Abgabe ergänzen
externe Beratung	Vertrag / Rechnung	vor Abgabe ergänzen
interne Personalkosten	Verrechnungssätze / Zeiterfassung	vor Abgabe ergänzen
messbarer Nutzen	Pilotmessung und Prozessdaten	nach Pilot auswerten

Für eine Produktiventscheidung sind neben den einmaligen Kosten auch laufende Betriebs-, Support-, Lizenz- und Schulungskosten sowie qualitative Nutzenbeiträge zu berücksichtigen.

4 Technische Konzeption

4.1 Zielarchitektur



Pilotgrenze: keine Ablösung des zentralen Identity Providers, kein unternehmensweiter Produktivrollout

Abbildung 8: Zielarchitektur und Pilotgrenze

Die Zielarchitektur ist modular aufgebaut. Das React-Frontend erfasst Rollenanforderungen und zeigt Statusinformationen. FastAPI stellt REST-Endpunkte für Antrag, Genehmigung, Rollenprüfung und Export bereit. PostgreSQL speichert Rollen, Zuordnungen und Auditdaten. GitHub Actions beziehungsweise die GitHub API übernehmen die kontrollierte Automatisierung.

Der zentrale Identity Provider bleibt außerhalb des Projekts. Für den Pilot kann die Authentisierung durch einen Testprovider oder signierte Testidentitäten simuliert werden. Eine produktive SSO-Integration erfordert ein separates Sicherheitsreview und eine abgestimmte Mandantenkonfiguration.

4.2 GitHub-Rollenworkflow

GitHub-basierter Rollenworkflow

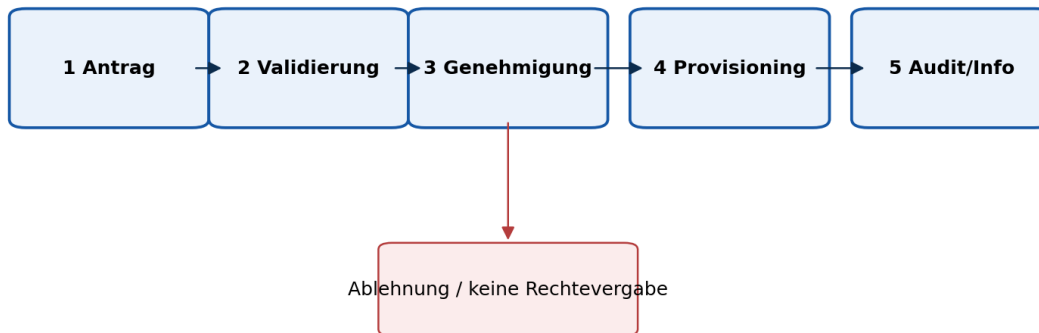


Abbildung 9: GitHub-basierter Rollenworkflow

Der Workflow trennt fachliche und technische Verantwortlichkeiten. Ein Antrag wird zunächst syntaktisch validiert, anschließend gegen Policies geprüft und danach einem Genehmiger zugewiesen. Erst eine positive Entscheidung löst das Provisioning aus. Ablehnungen und technische Fehler führen zu keiner Rechtevergabe.

4.3 Rollen- und Berechtigungsmodell

Tabelle 19: Pilotrollen und Berechtigungsumfang

Rolle	Zweck	Pilotberechtigungen
Admin	Administration des Piloten	Rollen und Policies verwalten, kein uneingeschränkter Produktivzugriff
Developer	Entwicklung in definierten Repositories	lesen/schreiben, Pull Requests
Reviewer	Qualitätssicherung	lesen, kommentieren, Review freigeben
Auditor	Nachweis und Prüfung	Audit-Logs und Exporte lesen
Read-Only	Informationszugriff	ausgewählte Repositories lesen
Approver	fachliche Genehmigung	Anträge genehmigen oder ablehnen

Das Rollenmodell vermeidet direkte Einzelberechtigungen, soweit dies technisch möglich ist. Rollen werden auf GitHub-Teams abgebildet. Jede Rolle erhält einen eindeutigen fachlichen Zweck, einen Genehmiger, zulässige Ressourcen und optional ein Ablaufdatum.

4.4 Datenmodell

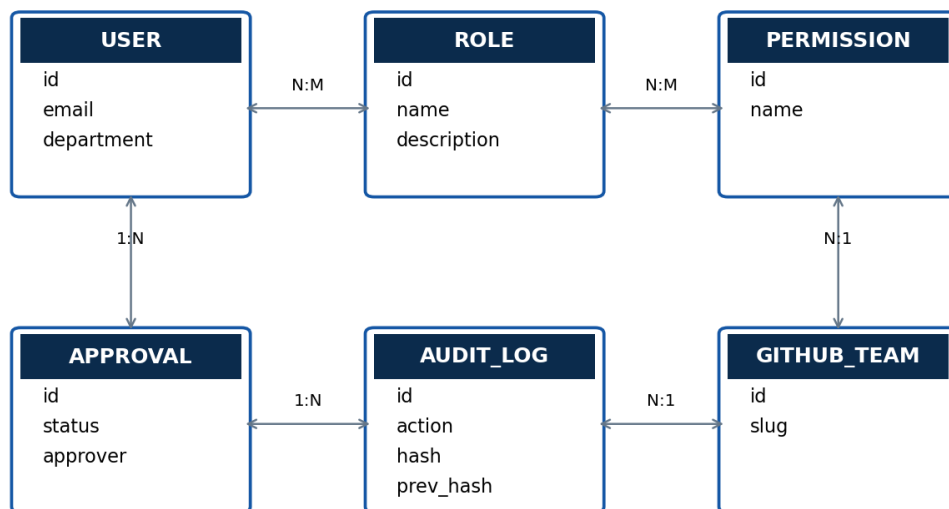


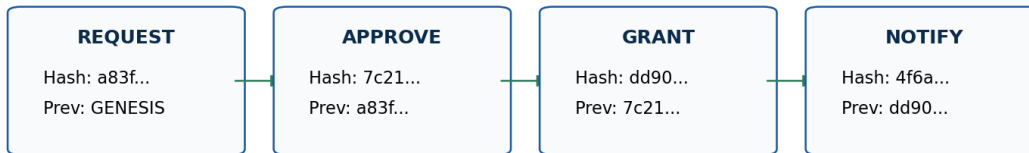
Abbildung 10: RBAC-Datenmodell des Piloten

Die Entitäten User, Role, Permission, Approval, GitHubTeam und AuditLog bilden die zentrale Nachweiskette.

Viele-zu-viele-Beziehungen werden über Zuordnungstabellen realisiert. Audit-Einträge referenzieren den fachlichen Vorgang und enthalten keine unnötigen Inhaltsdaten.

4.5 Audit- und Integritätskonzept

Manipulationserkennung durch Hash-Verkettung



Hinweis: Dies erhöht die Nachvollziehbarkeit, ersetzt aber keine formale Revisionsprüfung.

Abbildung 11: Hash-Verkettung der Audit-Ereignisse

Auditdaten werden append-only geschrieben und über einen Hash des aktuellen sowie des vorherigen Eintrags verkettet. Damit werden nachträgliche Veränderungen erkennbar. Datenbankadministratoren oder Plattformbetreiber besitzen technisch weiterhin weitreichende Möglichkeiten; deshalb wird bewusst von Manipulationserkennung und nicht pauschal von rechtlich bestätigter Revisionssicherheit gesprochen.

4.6 Schnittstellen

Tabelle 20: Schnittstellenübersicht

Schnittstelle	Methode/Protokoll	Zweck	Schutz
Portal - Backend	REST/HTTPS	Antrag und Status	Authentisierung, Validierung
Backend - GitHub	REST/HTTPS	Teamzuordnung	minimaler Token, Secrets Store
Backend - PostgreSQL	SQL/TLS	Rollen und Audit	DB-Rollen, Netzwerkgr enze
Workflow - Benachrichtigung	E-Mail/Mock	Statusmeldung	keine sensiven Details
Audit - Export	CSV/JSON	Prüfnachweis	Auditor-Rolle, Filter

4.7 Technische Sicherheitsmaßnahmen

- Keine Secrets im Repository; Nutzung eines Secrets Stores und kurzlebiger Testtoken.
- Branch Protection, Reviewpflicht und automatisierte Prüfungen für sicherheitsrelevante Änderungen.

- Eingabevalidierung, sichere Fehlerbehandlung und serverseitige Autorisierung.
- Getrennte Test- und Produktivkonfigurationen.
- Dependency- und Container-Scanning sowie dokumentierte Reaktion auf Findings.

4.8 API-Vertrag und Statusmodell

Die API bildet den Rollenprozess als explizite Zustandsmaschine ab. Zulässige Zustände sind DRAFT, SUBMITTED, VALIDATED, APPROVED, REJECTED, PROVISIONED, FAILED und REVOKED. Direkte Sprünge, beispielsweise von SUBMITTED zu PROVISIONED, werden serverseitig verhindert.

Tabelle 21: API- und Berechtigungsvertrag

Methode	Pfad	Zulässige Rolle	Ergebnis
POST	/role-requests	Antragsteller	Antrag in SUBMITTED
POST	/role-requests/{id}/validate	System	VALIDATED oder REJECTED
POST	/role-requests/{id}/approve	Genehmiger	APPROVED
POST	/role-requests/{id}/provision	Provisioner/System	PROVISIONED oder FAILED
POST	/role-requests/{id}/revoke	Administrator	REVOKED
GET	/audit/export	Auditor	gefilterter Nachweisexport

Idempotency-Keys verhindern doppelte Ausführung bei Wiederholungen. Fehlerantworten enthalten eine Korrelations-ID, aber keine Tokens, Stacktraces oder vertraulichen Konfigurationswerte.

4.9 Deployment- und Konfigurationskonzept

Die Pilotumgebung besteht aus getrennten Containern für Frontend, Backend und Datenbank. Konfigurationen werden über Umgebungsvariablen beziehungsweise Secrets eingebunden. Ein Compose-Setup unterstützt die lokale Reproduzierbarkeit; ein späteres produktives Deployment ist davon getrennt zu planen.

Tabelle 22: Deployment-Grenzen

Komponente	Pilotbetrieb	Produktivanforderung
Frontend	lokaler Container oder statischer Testhost	TLS, CSP, Monitoring
Backend	FastAPI-Container	Reverse Proxy, Rate Limits, Hochverfügbarkeit
PostgreSQL	isolierte Testdatenbank	Backup, Restore-Test, DB-Rollen
GitHub-Zugang	Testorganisation oder Dry-Run	App-Installation mit minimalen Scopes
Secrets	lokale sichere Variable / CI Secret	zentraler Vault und Rotation

Die Pilotkonfiguration ist nicht unverändert in Produktion zu übernehmen. Insbesondere Authentisierung, Schlüsselverwaltung, Backup, Monitoring und Netzwerksegmentierung benötigen eine separate Freigabe.

4.10 Fehler-, Retry- und Wiederanlaufkonzept

Externe API-Aufrufe können trotz korrekter Fachlogik scheitern. Der Workflow unterscheidet fachliche Ablehnung, temporären technischen Fehler und permanenten technischen Fehler. Nur temporäre Fehler werden begrenzt wiederholt.

Tabelle 23: Fehlerbehandlung

Fehlerklasse	Beispiel	Behandlung
fachlich	Policy verletzt	sofortige Ablehnung, keine Wiederholung
temporär	Timeout oder Rate Limit	maximal drei Retries mit Backoff
permanent	ungültiger Token-Scope	FAILED, Alarm und manuelle Klärung
unklarer Status	Antwort nach Timeout unbekannt	Ist-Zustand über API prüfen, nicht blind erneut provisionieren
Auditfehler	Log kann nicht geschrieben werden	Provisioning blockieren oder kompensieren

Ein erfolgreicher API-Status allein genügt nicht. Nach dem Provisioning wird der Zielzustand gelesen und mit dem erwarteten Team-beziehungsweise Rollenstatus verglichen.

4.11 Logging, Monitoring und Datenschutz

Betriebslogs und Auditlogs erfüllen unterschiedliche Zwecke. Betriebslogs unterstützen Fehleranalyse und Performancebeobachtung; Auditlogs dokumentieren fachlich relevante Sicherheitsereignisse. Beide Datenarten werden getrennt klassifiziert und mit unterschiedlichen Zugriffsrechten versehen.

Tabelle 24: Logging-Kategorien

Logart	Inhalt	Zugriff	Ausschluss
Betriebslog	Korrelations-ID, Dauer, Fehlercode	Betrieb/Entwicklung	Tokens, Passwörter, vollständige Begründungen
Auditlog	Akteur, Aktion, Ressource, Ergebnis	Auditor/Compliance	technische Stacktraces
Security-Finding	Scanner, Schweregrad, Fundstelle	Security/Owner	unnötige personenbezogene Daten

Monitoring-Kennzahlen umfassen Fehlerrate, Workflowdauer, Retry-Anzahl, abgelehnte Anträge und Audit-Schreibfehler. Schwellenwerte werden im Pilot beobachtet, aber erst nach ausreichender Datenbasis als SLA festgelegt.

5 Durchführungsphase

5.1 Entwicklungsumgebung und Repository

Die Umsetzung erfolgt in einem versionierten Repository mit klarer Verzeichnisstruktur für Backend, Frontend, Workflows, Tests und Dokumentation. Lokale Dienste werden über Container gestartet. Die CI-Pipeline führt Linting, Unit-Tests, Sicherheitsprüfungen und einen Build-Check aus.

5.2 Backend und Policy-Prüfung

Das FastAPI-Backend stellt typisierte Endpunkte bereit. Pydantic-Modelle validieren Pflichtfelder und erlaubte Werte. Die Policy-Schicht prüft Rollen, Ressourcen, Genehmiger und Trennung kritischer Funktionen. Nicht zulässige Kombinationen werden vor dem Provisioning blockiert und protokolliert.

5.3 Self-Service-Oberfläche

Die React-Oberfläche umfasst Dashboard, Rollenformular, Statusansicht und eine eingeschränkte Administrationsansicht. Rollenbeschreibungen und erwartete Genehmiger werden direkt im Formular angezeigt. Fehlermeldungen erläutern den nächsten Schritt, ohne technische oder sicherheitsrelevante Interna offenzulegen.

5.4 GitHub-Automatisierung

Ein Workflow übernimmt Validierung, Genehmigungsabfrage, Provisioning und Benachrichtigung. Für den Pilot wird zwischen echter API-Ausführung und Dry-Run unterschieden. Der Dry-Run erzeugt denselben Auditpfad, verändert aber keine externe Teamzuordnung. Dadurch kann der Prozess sicher vorgeführt und getestet werden.

5.5 Audit-Protokollierung

Jeder Zustandswechsel erzeugt ein strukturiertes Ereignis. Pflichtfelder sind Vorgangs-ID, Zeitstempel, Akteur beziehungsweise Systemkomponente, Aktion, Ergebnis und Referenz auf den vorherigen Hash. Exporte werden gefiltert und nur der Auditor-Rolle bereitgestellt.

5.6 Qualitätssicherung in der Umsetzung

- Pull-Request-Review für sicherheitskritische Änderungen.

- Unit-Tests für Validierung und Policies.
- Integrationstests für Antrag, Genehmigung, Provisioning und Audit.
- Secret- und Dependency-Scanning.
- Traceability von Anforderung über Implementierung zum Testfall.

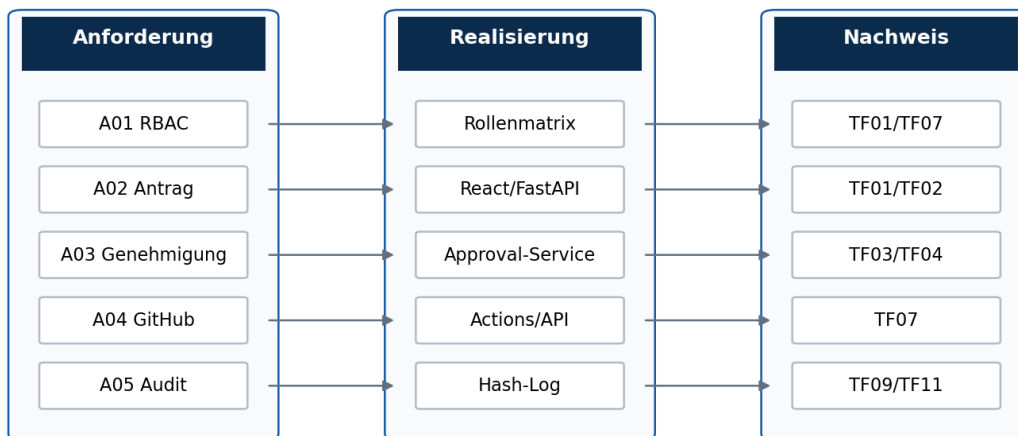


Abbildung 12: Traceability von Anforderungen, Realisierung und Nachweis

5.7 Abweichungsmanagement

Erkenntnisse, die den 70-Stunden-Rahmen überschreiten, werden als Restmaßnahme dokumentiert. Dazu gehören produktive SSO-Anbindung, organisationsweite Rollenkataloge, Rezertifizierung, Hochverfügbarkeit und SIEM-Integration. Diese Funktionen werden nicht verdeckt in den Pilot aufgenommen, sondern priorisiert in eine Roadmap überführt.

5.8 Implementierungsentscheidungen

FastAPI wurde gewählt, weil typisierte Request-Modelle, automatische OpenAPI-Dokumentation und eine klare Trennung der Services den Pilot unterstützen. React ermöglicht eine übersichtliche Self-Service-Oberfläche. PostgreSQL stellt Transaktionen, Constraints und flexible Auswertungen für Rollen- und Auditdaten bereit.

Die Technologieentscheidung ist kein allgemeines Urteil über andere Stacks. Entscheidend waren vorhandene Kenntnisse, Reproduzierbarkeit, Testbarkeit und der begrenzte Projektumfang. Ein Wechsel des Stacks hätte keinen ausreichenden zusätzlichen Projektnutzen erzeugt.

Tabelle 25: Zentrale Implementierungsentscheidungen

Entscheidung	Begründung	Konsequenz
FastAPI statt gemischter Backend-Stacks	einheitliche Python-Codebasis	weniger Toolwechsel und Widersprüche
Dry-Run für Provisioning	sicherer Demonstrationsbetrieb	Produktivwirkung separat freigeben
Hash-Verkettung	Manipulationen erkennbar machen	keine Behauptung formaler Revisionssicherheit
Rollen statt Einzelrechte	Wartbarkeit und Least Privilege	Rollenowner erforderlich

5.9 Dokumentations- und Repository-Struktur

Die Projektdokumentation und der technische Stand müssen auf denselben Liefergegenstand verweisen. Repository, Testbericht, Screenshots und PDF dürfen keine widersprüchlichen Technologien oder Statusangaben enthalten.

Tabelle 26: Empfohlene Repository-Struktur

Pfad	Inhalt
src/backend/	FastAPI-Endpunkte, Policies und Audit-Service
src/frontend/	React-Komponenten und Formulare
.github/workflows/	CI, Tests und Rollenworkflow
tests/	Unit-, Integrations- und Sicherheitstests
docs/	Architektur, Betrieb, Nutzung und Entscheidungen
reports/	reproduzierbare Test- und Scanergebnisse

Generierte Artefakte erhalten Version, Erstellzeitpunkt und Quellbezug. Screenshots werden als Simulation, Testumgebung oder Produktivansicht gekennzeichnet, damit ihre Aussagekraft eindeutig bleibt.

6 Test- und Pilotphase

6.1 Teststrategie

Die Teststrategie kombiniert Unit-, Integrations-, Sicherheits- und Abnahmetests. Testdaten sind synthetisch. Jeder Muss-Anforderung ist mindestens ein Testfall zugeordnet. Kritische Fehler in Autorisierung, Provisioning oder Audit blockieren die Freigabe.

6.2 Testfälle

Tabelle 27: Testfallmatrix

ID	Testobjekt	Erwartetes Ergebnis	Status
TF01	Rollenantrag	gültiger Antrag wird angelegt	laut Unterlagen bestanden
TF02	Pflichtfelder	unvollständiger Antrag wird abgewiesen	laut Unterlagen bestanden
TF03	Genehmigung	positive Entscheidung setzt Workflow fort	laut Unterlagen bestanden
TF04	Ablehnung	keine Rechtevergabe	laut Unterlagen bestanden
TF05	Policy erlaubt	zulässige Kombination wird akzeptiert	laut Unterlagen bestanden
TF06	Policy blockiert	unzulässige Kombination wird gestoppt	laut Unterlagen bestanden
TF07	Provisioning	Teamzuordnung oder Dry-Run erfolgreich	laut Unterlagen bestanden
TF08	Rechteentzug	Rolle wird entzogen und protokolliert	laut Unterlagen bestanden
TF09	Audit-Eintrag	vollständiges Ereignis vorhanden	laut Unterlagen bestanden
TF10	Secret-Scan	kein produktives Secret gefunden	laut Unterlagen bestanden
TF11	Audit-Export	gefilterter Export wird erzeugt	laut Unterlagen bestanden
TF12	Benachrichtigung	Statusmeldung wird erstellt	laut Unterlagen bestanden

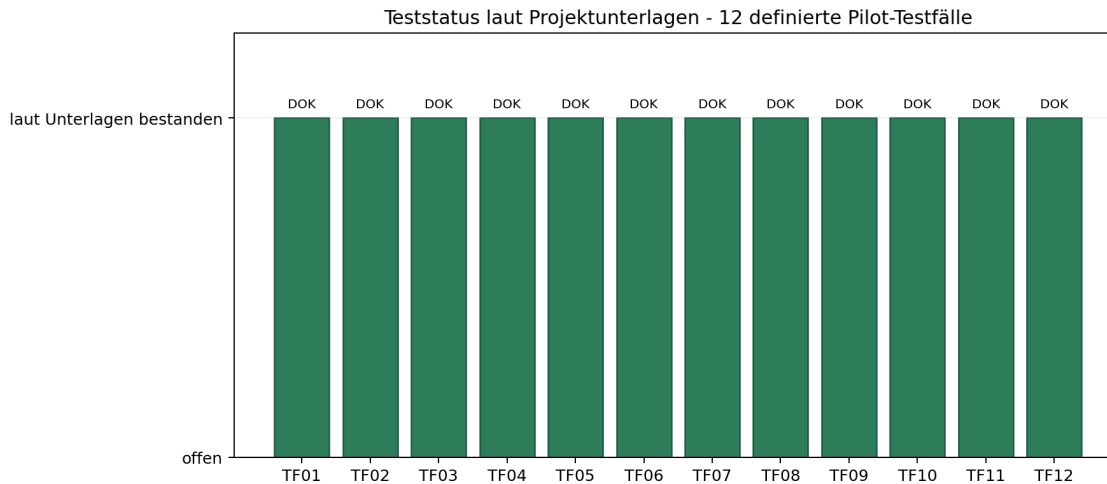


Abbildung 13: Ergebnisübersicht des automatisierten Pilot-Testlaufs

Der Teststatus beschreibt den technischen Pilotstand. Er ist kein Nachweis eines unternehmensweiten Produktivbetriebs. Für eine spätere Abnahme sind zusätzlich reale Rollenverantwortliche, produktive Schnittstellen, Datenschutzfreigabe und Betriebsanforderungen zu prüfen.

6.3 Fehler- und Abweichungsanalyse

Tabelle 28: Behobene Pilotbefunde

Befund	Auswirkung	Korrektur
fehlender Zeitstempel in Audit-Event	Nachweis unvollständig	Pflichtfeld und Negativtest ergänzt
unklare Admin-Rollenabgrenzung	zu hohe Berechtigung möglich	Rolle getrennt und Policy verschärft
fehlende Ablehnungsbenachrichtigung	Status für Antragsteller unklar	Notification-Pfad ergänzt
API-Fehler ohne Retry	temporärer Ausfall führt zu Abbruch	begrenzter Retry und Fehlerstatus

6.4 Soll-Ist-Vergleich

Tabelle 29: Soll-Ist-Vergleich

Kriterium	Soll	Pilot-Ist	Bewertung
Rollenmodell	mindestens 6 Rollen	6 Rollen dokumentiert	erreicht
Workflow	5 Prozessstufen	5 Stufen mit Fehlerpfad	erreicht
Audit	vollständige Pilotereignisse	strukturierter Export und Hash-Kette	erreicht
Tests	12 definierte Testfälle	12/12 laut Projektunterlagen; Testreport beizulegen	nachzuweisen
Produktivbetrieb	nicht Bestandteil	nicht durchgeführt	abgegrenzt
Betriebliche Abnahme	separater Nachweis	vor Produktivfreigabe erforderlich	offen

6.5 Abnahmevoraussetzungen

Eine endgültige betriebliche Abnahme darf erst dokumentiert werden, wenn eine berechtigte auftraggebende Stelle die Muss-Kriterien geprüft und ein Abnahmeprotokoll unterzeichnet hat. Die vorliegende Arbeit enthält deshalb eine Abnahmevorlage, aber keine erfundene Unterschrift oder unbestätigte Freigabe.

Vor IHK-Einreichung müssen tatsächliche Abnahme, Testprotokolle, Repository-Stand und Projektzeitrachweis miteinander übereinstimmen.

6.6 Evidenz- und Reproduzierbarkeitskonzept

Ein Testergebnis ist nur dann belastbar, wenn Testversion, Eingabedaten, erwartetes Ergebnis und tatsächliches Ergebnis nachvollziehbar sind. Die Dokumentation verweist deshalb auf automatisierte Reports und nicht ausschließlich auf dekorative Screenshots.

Tabelle 30: Mindestanforderungen an Projektnachweise

Nachweis	Mindestinhalt
Testreport	Commit/Version, Test-ID, Ergebnis, Laufzeit
Security-Scan	Scanner-Version, Scope, Findings und Bewertung
API-Nachweis	Request-Korrelation, Status und verifizierter Zielzustand
Audit-Export	Vorgangs-ID, vollständige Ereigniskette, Hash-Prüfung
Screenshot	Umgebung, Zeitpunkt, Simulation/Test/Produktion

Persönliche Daten und Secrets werden vor der Aufnahme in die Projektarbeit anonymisiert. Eine visuelle Darstellung darf den Sachverhalt verdeutlichen, aber keine nicht vorhandene Produktivumgebung vortäuschen.

6.7 Abnahme- und Restpunktelogik

Die Abnahme unterscheidet kritische, wesentliche und geringfügige Restpunkte. Kritische Restpunkte verhindern jede Freigabe. Wesentliche Restpunkte erlauben höchstens eine eingeschränkte Pilotfreigabe mit Termin und Verantwortlichem. Geringfügige Punkte können dokumentiert nachgezogen werden.

Tabelle 31: Klassifizierung von Abnahmebefunden

Klasse	Beispiel	Freigabewirkung
kritisch	Autorisierung umgehbar, Audit fehlt, Secret exponiert	keine Freigabe
wesentlich	Retry/Benachrichtigung unvollständig	nur begrenzter Pilot mit Maßnahme
geringfügig	Text- oder Darstellungsfehler	Freigabe möglich, Nacharbeit terminieren

Die Entscheidung wird im Abnahmeprotokoll festgehalten. Ein leeres Formular oder eine vom Projektverfasser selbst eingesetzte Unterschrift ist kein Abnahmenachweis.

6.8 Projektstatusbericht zum Dokumentationsstichtag

Tabelle 32: Projektstatusbericht

Dimension	Status	Begründung / Maßnahme
Leistung	grün	Muss-Funktionen des technischen Piloten und Dokumentation vorhanden
Zeit	gelb	finale Ist-Zeiten sind mit dem persönlichen Zeitznachweis abzugleichen
Kosten	grün	kalkulatorische Kostenbasis konsistent; keine neuen Enterprise-Lizenzen
Qualität	grün	Anforderungs-Test-Zuordnung und kritische Fehlerlogik dokumentiert
Betriebliche Abnahme	gelb	Unterzeichnung und betriebliche Freigabe bleiben gesonderter Auftraggebernachweis

Der Gesamtstatus wird nach der ungünstigsten Einzelbewertung als gelb geführt. Der technische Pilot ist abgeschlossen; für eine betriebliche Produktivfreigabe sind insbesondere die benannten Owner, der produktive Identity Provider, Datenschutzfreigaben und ein unterzeichnetes Abnahmeprotokoll erforderlich.

7 Rollout, Schulung und Betriebsübergabe

7.1 Pilotbetrieb

Der Pilotbetrieb erfolgt mit einem kleinen, kontrollierten Nutzerkreis und synthetischen beziehungsweise freigegebenen Testidentitäten. Zunächst werden nur unkritische Rollen und Test-Repositories einbezogen. Der Rollout wird gestoppt, wenn ein kritischer Fehler in Autorisierung, Audit oder Rechteentzug auftritt.

7.2 Schulungs- und Kommunikationskonzept

- 30-minütige Einweisung für Antragsteller und Genehmiger.
- Administrator-Guide für Rollenpflege, Fehlerstatus und Audit-Export.
- Kurzanleitung mit Rollenbeschreibung, Genehmigungsweg und Supportkontakt.
- Feedbackkanal für Unklarheiten und Verbesserungswünsche.

7.3 Betriebsübergabe

Die Übergabe umfasst Architekturübersicht, Deployment-Anleitung, Rollenmatrix, Schnittstellenbeschreibung, Testprotokoll, Restmaßnahmen und Notfallhinweise. Ein Betrieb ohne benannten Owner, Backup-Verfahren und Secret-Rotation ist nicht zulässig.

7.4 Rollout- und Skalierungsroadmap

Einführungs- und Skalierungsroadmap

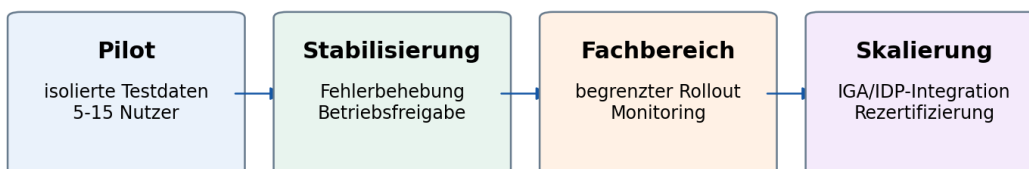


Abbildung 14: Einführungs- und Skalierungsroadmap

Erst nach Stabilisierung des Piloten folgt eine mögliche Integration in einen zentralen Identity Provider oder eine IGA-Plattform. Die

Pilotkomponenten können dabei als Referenz für Genehmigungslogik, Rollenbeschreibung und Audit-Nachweise weiterverwendet werden.

7.5 Betriebsmodell und Verantwortungsübergang

Nach dem Pilot benötigt jede Komponente einen Owner. Fachliche Rollenowner entscheiden über Inhalt und Genehmigungsweg; der technische Owner verantwortet Verfügbarkeit, Secrets, Updates und Fehlerbehandlung; Datenschutz und Informationssicherheit prüfen die vorgesehenen Kontrollen.

Tabelle 33: Betriebsrollen

Verantwortung	Aufgabe
Service Owner	Nutzen, Budget, Freigaben und Prioritäten
Rollenowner	Berechtigungsinhalt und Rezertifizierung
Technischer Betrieb	Deployment, Backup, Monitoring, Incident-Behandlung
Security/Datenschutz	Kontrollreview, Findings und Aufbewahrung
Support	Anwenderfragen und standardisierte Eskalation

Die Übergabe ist erst vollständig, wenn Zugänge, Dokumentation, Notfallkontakte, bekannte Einschränkungen und Restmaßnahmen übergeben und verstanden wurden.

8 Projektabschlussphase und Wirtschaftlichkeit

8.1 Projektergebnis

Das Projekt liefert einen abgegrenzten und testbaren Zero-Trust-Rollenworkflow. Die zentrale Leistung besteht nicht in einer vollständigen IAM-Einführung, sondern in der strukturierten Übersetzung von fachlichen Anforderungen in Rollen, Policies, technische Schnittstellen und reproduzierbare Nachweise.

8.2 Kosten- und Nutzenbewertung

Der Projektvorschlag nennt einen Budgetrahmen von ca. 50.000 EUR. Eine belastbare Nachkalkulation kann erst nach Einsetzen der tatsächlichen Lizenz-, Schulungs-, Beratungs- und internen Personalkosten sowie der gemessenen Prozessverbesserung erfolgen.

8.3 Lessons Learned

- Eine enge Projektabgrenzung erhöht Glaubwürdigkeit und Prüfbarkeit.
- Zeit- und Kostenmodelle müssen aus einer einzigen konsistenten Basis stammen.
- Technische Screenshots ersetzen keine nachvollziehbare Anforderungs- und Testkette.
- Auditierbarkeit ist präziser zu beschreiben als pauschale Revisionssicherheit.
- Standard-IAM-Lösungen sind nicht funktional abzuwerten; die Entscheidung muss projektspezifisch erfolgen.
- Produktivwerte, Pilotwerte, Planwerte und belegte Ist-Werte müssen sichtbar getrennt werden.

8.4 Restrisiken

Tabelle 34: Restrisiken und Folgemaßnahmen

Restrisiko	Maßnahme vor Rollout
Betriebsverantwortung ungeklärt	Owner und Supportmodell benennen
Produktive SSO-Integration ungeprüft	Security- und Datenschutzreview durchführen
Rollen wachsen unkontrolliert	Owner, Ablaufdatum und Rezertifizierung definieren
Auditdaten werden zu lange gespeichert	Aufbewahrungs- und Löschkonzept freigeben
GitHub-/API-Abhängigkeit	Fehlerbetrieb, Limits und Exit-Option dokumentieren

8.5 Persönliches Fazit

Die Projektarbeit verbindet Projektmanagement, Wirtschaftlichkeit, Datenschutz und technische Umsetzung. Der wichtigste Erkenntnisgewinn liegt in der konsequenten Trennung zwischen einem realistisch umsetzbaren Pilot und einer späteren Unternehmenslösung. Durch die konsistente Nachweiskette kann der Pilot sachlich bewertet und gezielt weiterentwickelt werden.

8.6 Gesamtbewertung gegen das magische Dreieck

Das Projekt wird abschließend gegen Leistung, Zeit und Kosten bewertet. Der Leistungsumfang wurde im Prüfungsnachweis auf einen Pilot begrenzt. Der persönliche aktive Prüfungsaufwand beträgt 70 Stunden; der betriebliche Budgetrahmen des Projektvorschlags beträgt ca. 50.000 EUR. Qualitäts- und Sicherheitskriterien werden nicht zugunsten zusätzlicher Funktionen abgesenkt.

Tabelle 35: Abschlussbewertung

Dimension	Ergebnis	Bewertung
Leistung	Muss-Funktionen des Piloten und Dokumentation	erfüllt, Produktivumfang abgegrenzt
Zeit	70 aktive Prüfungsstunden im 13-Wochen-Rahmen	Planbasis gemäß Projektvorschlag
Kosten	ca. 50.000 EUR Budgetrahmen	Ist-Kosten nachzuweisen
Qualität	Traceability, Tests und Restpunktlogik	nachweisorientiert
Risiko	kritische Produktivthemen in Roadmap verschoben	kontrolliert

Die wichtigste Steuerungsentscheidung war der Verzicht auf eine überzogene Vollimplementierung. Dadurch bleibt das Ergebnis fachlich verteidigbar und lässt sich anhand konkreter Artefakte demonstrieren.

9 Quellen und methodische Grundlagen

1. IHK-Projektvorschlag Daniel Massa, Prüflingsnummer 615951, Zero-Trust-Sicherheitskonzept mit GitHub-Integration, Stand 30.09.2026.
2. NIST: SP 800-207, Zero Trust Architecture, 2020.
3. ISO/IEC 27001:2022, Information security management systems - Requirements.
4. ISO/IEC 27002:2022, Information security controls.
5. Verordnung (EU) 2016/679, insbesondere Art. 5, 25 und 32.
6. BSI: IT-Grundschutz-Kompendium, Bausteine zu Identitäts- und Berechtigungsmanagement.
7. GitHub Documentation: GitHub Actions und REST API.
8. Projektmanagement-Unterlagen und IHK-Lehrgangsmaterialien des Nutzers, insbesondere Projektanbahnung, Projektorganisation und Technischer Entwurf.
9. Formale Richtlinie Projektarbeit IT Professional, bereitgestellte Fassung November 2021.
10. Projektdokumentation Certified IT Business Manager - Kommunikationsplattform, strukturelle Referenz für Projektmanagement, Controlling und Abschluss.
11. Projektarbeit HOMAG Partner Portal, strukturelle Referenz für Eigenleistung, Planung und analytische Begründungen.
12. Projektdokumentation StreamServe-Migration, strukturelle Referenz für Abweichungssteuerung, Meilensteintrendanalyse und Lessons Learned.

Die Web- und Herstellerdokumentation ist vor der Abgabe auf Version, Abrufdatum und konkrete Kapitelangabe zu prüfen. Interne Quellen sind mit Titel, Version, Datum und Freigabestatus zu benennen.

Eidesstattliche Erklärung

Ich versichere, dass ich die vorliegende Projektarbeit selbstständig verfasst und keine anderen als die angegebenen Quellen und Hilfsmittel benutzt habe. Alle Stellen, die wörtlich oder sinngemäß aus veröffentlichten oder nicht veröffentlichten Quellen übernommen wurden, sind als solche kenntlich gemacht.

Stuttgart, den 01.11.2026

Daniel Massa

Anhang

A1 Bestätigte Projektstammdaten und Zeitplan

Tabelle 36: Bestätigte Stammdaten aus dem IHK-Projektvorschlag

Feld	Bestätigter Wert
Prüfungsteilnehmer	Daniel Massa
Prüflingsnummer	615951
Wohnanschrift	Hackstraße 41, 70190 Stuttgart
Mobiltelefon	+49 178 2989360
E-Mail	Massa.Daniel@proton.me
Projekt-/Praktikumsbetrieb	Verein zur Förderung der Berufsbildung e. V.
Betriebsanschrift	Kurfürstenstraße 6, 71636 Ludwigsburg
Projektfeld	IT-Projektmanagement / IT-Sicherheit / digitale Verwaltung / Zugriffskontrolle
Projektcoach	Carsten Vordermeier
Kontakt Projektcoach	07136 396663 / vordermeier@c-tim.de
Projektvorschlag	30.09.2026
Abgabedatum Dokumentation	01.11.2026
Projektlaufzeit laut Vorschlag	13 Wochen
Budgetrahmen laut Vorschlag	ca. 50.000 EUR

A1.1 Detaillierter Zeitplan

Tabelle 37: Detaillierte Aufwandssicht

Phase laut Antrag	Wesentliche Arbeitspakete	Stunden
1 Projektinitialisierung und Analyse	Projektauftrag, Ist-Analyse, Anforderungen, Risikoprofil	15
2 Konzept und Architektur design	Zero-Trust-Framework, Architektur-Blueprint, Stakeholderfreigabe	15
3 Implementierung und GitHub-Integration	RBAC, Workflows, Schnittstellen, Audit- und Sicherheitsprüfungen	25
4 Test und Schulung	Funktionstests, Audit-Prüfung, Schulungskonzept und Feedback	8
5 Projektabschluss und Übergabe	Dokumentation, Abnahmevorbereitung, Lessons Learned und Übergabe	7
Gesamt		70

A2 Projektstrukturplan

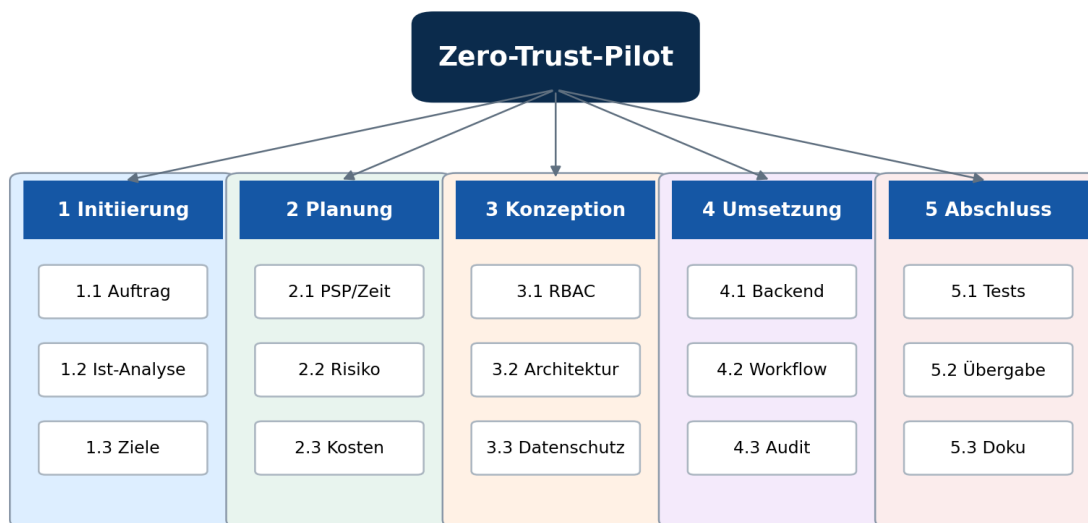


Abbildung 15: Projektstrukturplan - Anhangswiederholung

A3 Risikoanalyse

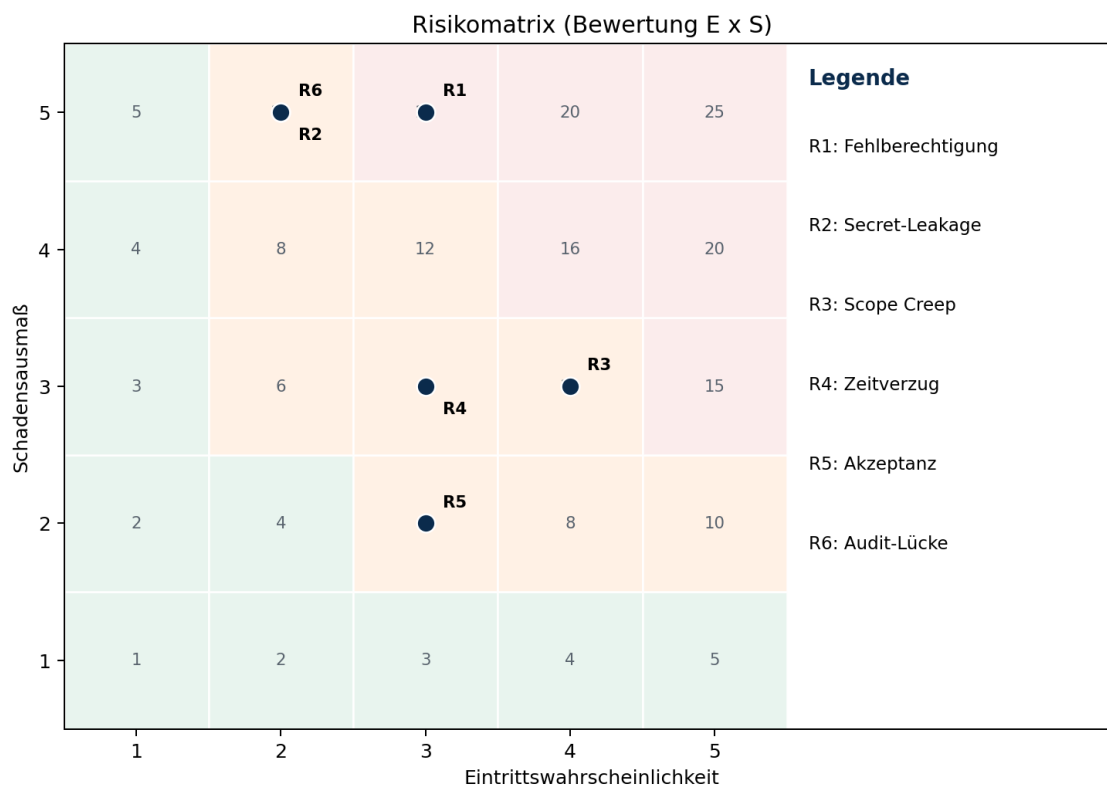
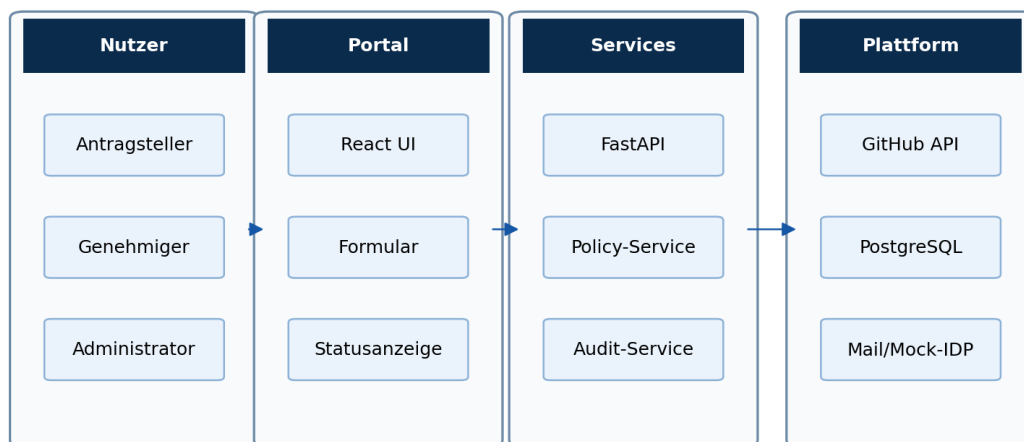


Abbildung 16: Risikomatrix - Anhangswiederholung

Tabelle 38: Risikoregister

Risiko	Bewertung	Prävention	Reaktion
Fehlberechtigung	hoch	Rollenmatrix, Vier-Augen-Prinzip	Entzug, Audit, Ursachenanalyse
Secret-Leakage	hoch	Secrets Store, Scanner, Testtoken	Token sperren und ersetzen
Scope Creep	mittel	Abgrenzung, Change-Entscheidung	Anforderung verschieben
Zeitverzug	mittel	Meilensteine, Puffer, Priorisierung	Kann-Anforderung entfernen
Audit-Lücke	hoch	Pflichtlogging, Tests	Blockierung des Provisionings

A4 Architektur und Workflow



Pilotgrenze: keine Ablösung des zentralen Identity Providers, kein unternehmensweiter Produktivrollout

Abbildung 17: Zielarchitektur - Detailansicht

GitHub-basierter Rollenworkflow

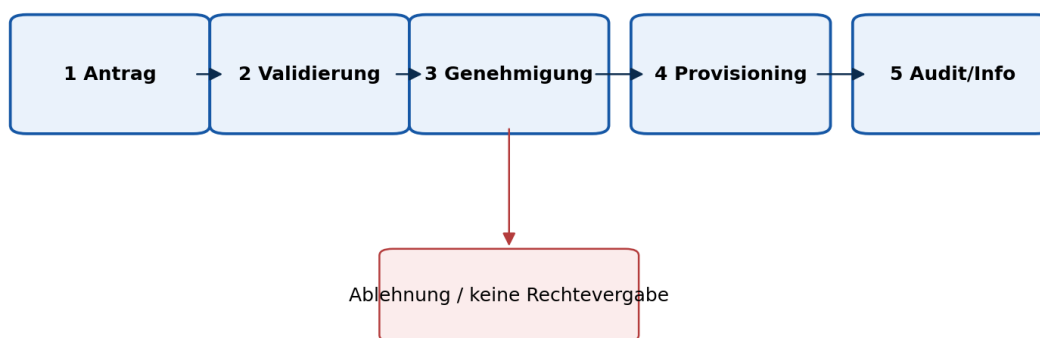


Abbildung 18: Workflow - Detailansicht

A5 Datenmodell und Audit

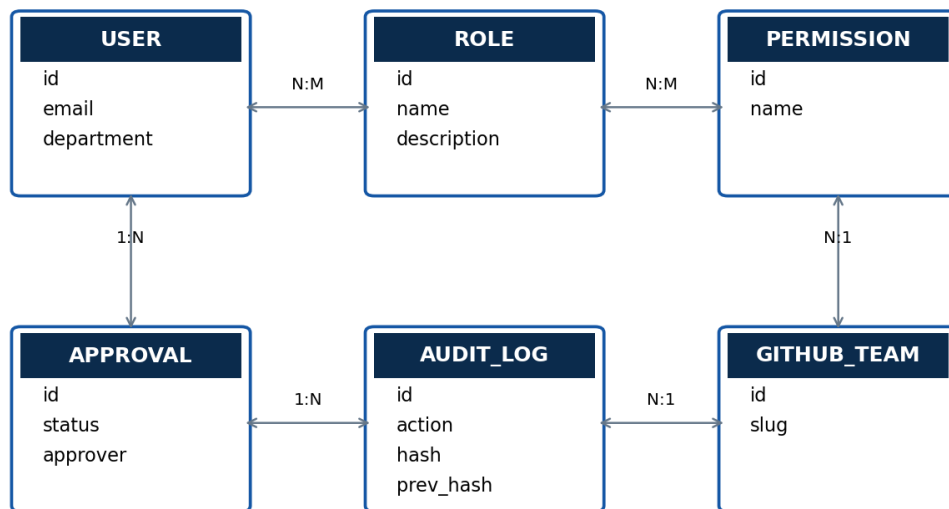
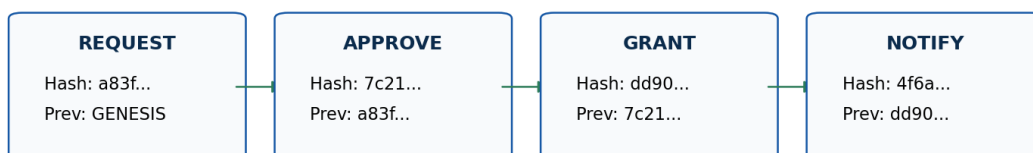


Abbildung 19: Datenmodell - Detailansicht

Manipulationserkennung durch Hash-Verkettung



Hinweis: Dies erhöht die Nachvollziehbarkeit, ersetzt aber keine formale Revisionsprüfung.

Abbildung 20: Audit-Hash-Kette - Detailansicht

A6 Anforderungs- und Testnachweis

Tabelle 39: Anforderungsnachweis

ID	Anforderung	Typ	Priorität	Nachweis
A01	Rollenbasierte Berechtigungen	funktional	Muss	Rollenmatrix / TF07
A02	Strukturierter Self-Service-Antrag	funktional	Muss	Formular / TF01-TF02
A03	Explizite Genehmigungsentscheidung	funktional	Muss	Workflow / TF03-TF04
A04	GitHub-Teamzuordnung	funktional	Muss	API-/Simulationslog / TF07
A05	Audit-Protokollierung	nicht-funktional	Muss	Audit-Export / TF09-TF11
A06	Sicherer Rechteentzug	funktional	Muss	TF08
A07	Secret-Scanning	Sicherheit	Muss	TF10
A08	Betriebs- und Nutzerdokumentation	Organisation	Muss	Dokumentenpaket

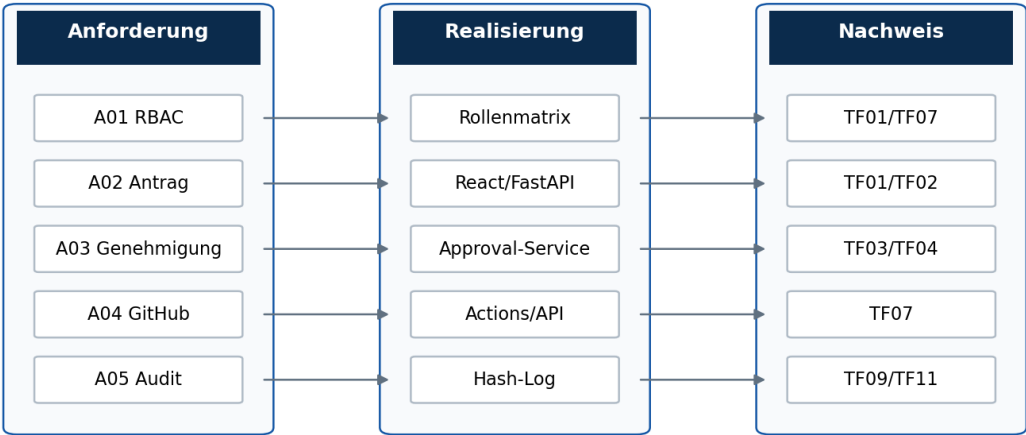


Abbildung 21: Traceability-Matrix - Detailansicht

A7 Testprotokoll

Tabelle 40: Testprotokoll - Pilot

ID	Testobjekt	Erwartetes Ergebnis	Status
TF01	Rollenantrag	gültiger Antrag wird angelegt	laut Unterlagen bestanden
TF02	Pflichtfelder	unvollständiger Antrag wird abgewiesen	laut Unterlagen bestanden
TF03	Genehmigung	positive Entscheidung setzt Workflow fort	laut Unterlagen bestanden
TF04	Ablehnung	keine Rechtevergabe	laut Unterlagen bestanden
TF05	Policy erlaubt	zulässige Kombination wird akzeptiert	laut Unterlagen bestanden
TF06	Policy blockiert	unzulässige Kombination wird gestoppt	laut Unterlagen bestanden
TF07	Provisioning	Teamzuordnung oder Dry-Run erfolgreich	laut Unterlagen bestanden
TF08	Rechteentzug	Rolle wird entzogen und protokolliert	laut Unterlagen bestanden
TF09	Audit-Eintrag	vollständiges Ereignis vorhanden	laut Unterlagen bestanden
TF10	Secret-Scan	kein produktives Secret gefunden	laut Unterlagen bestanden
TF11	Audit-Export	gefilterter Export wird erzeugt	laut Unterlagen bestanden
TF12	Benachrichtigung	Statusmeldung wird erstellt	laut Unterlagen bestanden

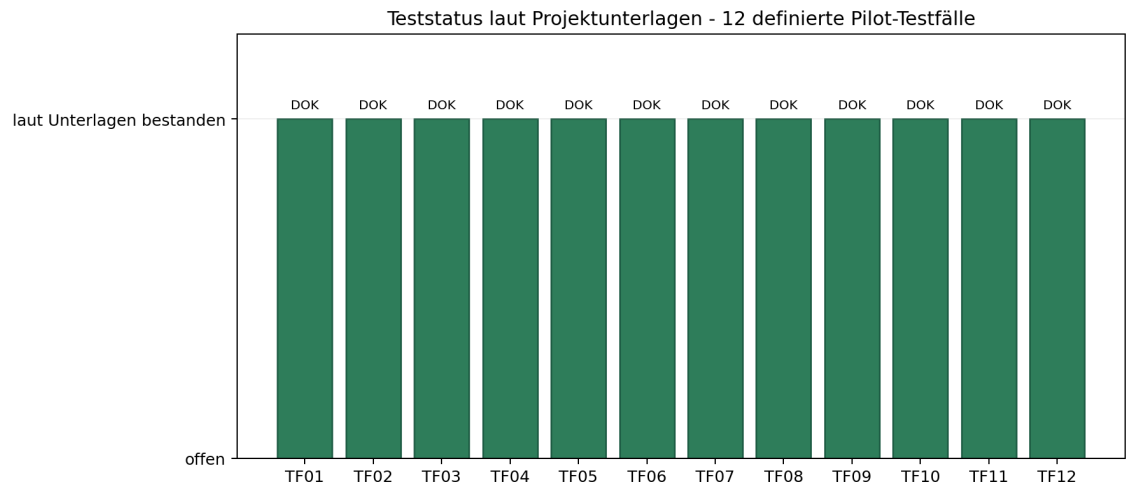


Abbildung 22: Teststatus - Detailansicht

A8 Abnahmevorlage

Tabelle 41: Abnahmecheckliste

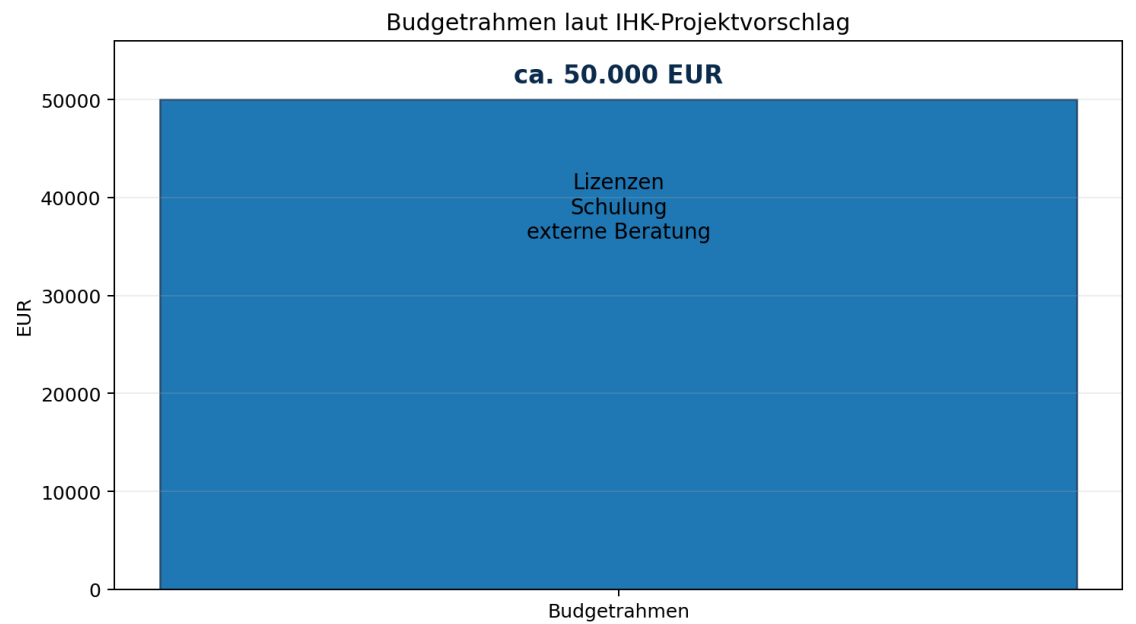
Prüfpunkt	Ergebnis	Nachweis / Bemerkung
Muss-Anforderungen erfüllt	☐ ja ☐ nein	
Testfälle nachvollziehbar	☐ ja ☐ nein	
Kritische Findings geschlossen	☐ ja ☐ nein	
Betriebs- und Datenschutzfreigabe	☐ ja ☐ nein	
Restmaßnahmen terminiert	☐ ja ☐ nein	
Pilot freigegeben	☐ ja ☐ nein	

Auftraggeber / Rolle: _____

Datum: _____ Unterschrift: _____

Diese Seite ist eine Vorlage. Sie darf erst nach realer Prüfung und Unterschrift als Abnahmeprotokoll bezeichnet werden.

A9 Budget- und Nachkalkulationsrahmen



Die 70 Prüfungsstunden des Teilnehmers sind nicht mit dem Gesamtprojektbudget gleichzusetzen.

Abbildung 23: Budgetrahmen - Detailansicht

Tabelle 42: Budget- und Nachkalkulationsdaten

Parameter	Wert / Status
Gesamtbudget laut Projektvorschlag	ca. 50.000 EUR
Budgetkategorien	Lizenzen, Schulung, externe Beratung
Persönlicher Prüfungsaufwand	70 aktive Stunden
Ist-Kosten	durch Angebote, Rechnungen und interne Verrechnungssätze zu ergänzen
Ist-Nutzen	nach Pilot anhand realer Prozessdaten zu messen
Break-even / ROI	erst nach belastbarer Nachkalkulation ausweisen

A10 Rollout-Roadmap

Einführungs- und Skalierungsroadmap

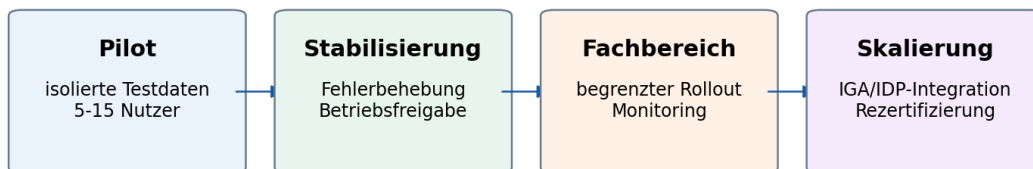


Abbildung 24: Rollout- und Skalierungsroadmap - Detailansicht

Die Roadmap ist keine Freigabe für einen Produktivrollout. Jede Stufe erfordert eigene Eintritts- und Austrittskriterien sowie einen benannten Verantwortlichen.

A11 Kick-off- und Gesprächsprotokoll

Tabelle 43: Kick-off-Protokoll

Feld	Inhalt
Projekt	Zero-Trust-Sicherheitskonzept mit GitHub-Integration
Ziel	technischer Pilot mit nachvollziehbarer Genehmigung, Provisioning und Audit
Teilnehmerrollen	Projektleiter Daniel Massa, Projektcoach Carsten Vordermeier, 2 IT-Spezialisten, Automatisierungsentwickler, externer Compliance-Berater
Beschlüsse	Pilotabgrenzung, sechs Meilensteine, Repository als Projekttakte, kritische Fehler blockieren Freigabe
Offene Punkte	betriebliche Owner, produktive SSO-Integration, Aufbewahrungsfrist, Abnahmeunterschrift
Protokollverantwortung	Daniel Massa, Projektleiter

Datum / Ort: _____

Freigabe Auftraggeber: _____

A12 Projektstatusbericht

Tabelle 44: Projektstatus zum Dokumentationsstichtag

Rubrik	Stand	Nächste Aktion	Verantwortung
Leistung	Pilot-Scope laut Projektunterlagen umgesetzt	Repository- und Betriebsnachweise final zuordnen	Projektleiter / Auftraggeber
Termin	Pilotdokumentation erstellt	Ist-Zeitnachweis finalisieren	Projektleiter
Kosten	Budgetrahmen ca. 50.000 EUR	Ist-Kosten aus Angeboten/Rechnungen nachführen	Projektleiter / Auftraggeber
Risiken	kritische Pilotfehler laut Unterlagen geschlossen	Security- und Datenschutzfreigabe dokumentieren	IT / Compliance
Entscheidung	technischer Pilot beurteilbar	betriebliche Abnahme und Rolloutentscheidung	Auftraggeber

Gesamtstatus: GELB - Projektstammdaten und Planbasis bestätigt; Test-, Ist-Kosten- und Abnahmenachweise müssen der endgültigen Abgabefassung eindeutig zugeordnet werden.